VAPTOR Security Assessment Report

Organization: VAPTOR001
Scan ID: SCAN20260311121627
Generated (UTC): 2026-03-11 15:36:10

1) Executive Summary

This assessment summarizes discovered assets, exposed services, and validated findings. MAC addresses are included where available to help correlate devices across scans in DHCP/dynamic IP environments.

Metric	Value
Assets assessed	16
Total vulnerabilities	51
Impact score	20/100
Overall control compliance	0% (0/74)

Severity breakdown

Severity	Count
Critical	0

Severity	Count
High	0
Medium	20
Low	16
Info	15

Assets Scanned

AssetUID	Asset IP	Asset MAC	Open Ports	Vuln Count
VAPTOR001A0001	178.79.134.182	—	4445	32
VAPTOR001A0002	81.169.145.156	—	21, 80, 443, 8080	13
VAPTOR001A0003	137.74.187.100	—	80, 443	0
VAPTOR001A0004	31.3.96.40	—	22, 80, 443	6
VAPTOR001A0005	44.228.249.3	—	80	0
VAPTOR001A0006	44.238.29.244	—	80	0
VAPTOR001A0007	10.0.0.132	B8:27:EB:74:F2:6C	22	0
VAPTOR001A0008	10.0.0.105	38:53:9C:B8:D1:98	49152, 62078	0

AssetUID	Asset IP	Asset MAC	Open Ports	Vuln Count
VAPTOR001A0009	10.0.0.104	74:40:BB:72:FB:C5	6881	0
VAPTOR001A0010	10.0.0.112	42:27:0A:23:DF:92	—	0
VAPTOR001A0011	10.0.0.110	3C:0A:F3:3C:C1:A7	—	0
VAPTOR001A0012	10.0.0.254	70:F8:2B:1B:A3:68	53, 80, 443, 1990	0
VAPTOR001A0013	10.0.0.134	00:0c:29:70:f3:3f	—	0
VAPTOR001A0014	10.0.0.124	04:CB:01:4C:1B:1C	—	0
VAPTOR001A0015	10.0.0.133	16:41:0F:EC:FD:25	—	0
VAPTOR001A0016	10.0.0.106	F4:63:1F:59:71:1C	—	0

Watchdog Answers

- **What is exposed?** 16 assets with 28 open TCP ports; 14 high-risk exposed service(s).
- **What is vulnerable?** 51 validated finding(s) (Critical 0, High 0, Medium 20).
  Top findings: MEDIUM: CSP: style-src unsafe-inline; MEDIUM: CSP: Wildcard Directive; MEDIUM: CSP: Failure to Define Directive with No Fallback
- **What is the evidence?** Evidence snippets present for 51/51 finding(s). See per-asset finding notes for captured headers, fingerprints, and observed behaviors.
- **What is the risk/impact?** Impact score 20/100. Compliance posture: 9% control coverage and 0% vuln-to-control mapping.

- **What should we do next?** Prioritize CRITICAL/HIGH fixes first, then reduce high-risk exposure and re-scan to confirm closure.
  Top actions: Restrict exposure of 10.0.0.132:22 (HIGH). Implement key-based authentication only. Disable password authentication. Use fail2ban. Restrict access by IP. Enable 2FA.; Restrict exposure of 10.0.0.254:80 (HIGH). Redirect all traffic to HTTPS (port 443). Disable HTTP or use only for redirect. Implement HSTS headers.; Restrict exposure of 137.74.187.100:80 (HIGH). Redirect all traffic to HTTPS (port 443). Disable HTTP or use only for redirect. Implement HSTS headers.

2) Technical Summary

Key technical metrics derived from discovery artifacts and assessment outputs:

Metric	Value
Impact score	20/100
Assets discovered	16
Open TCP ports discovered (state=open)	28

Scanner Execution Status

This section records which scanners executed, were skipped, or were unavailable for this run.

Scanner	Status
VAPTORAPI — Vaptor Intelligence	Completed

Scanner	Status
VAPTORSCOUT — Discovery	Completed
VAPTORRECON — Vulnerability Assessment	Completed
VAPTORWEB — Web Scanner	Completed with Warnings
VAPTORSQL — SQL Verification	Completed
VAPTORMSF — Exploit Verification	Completed
VAPTORFW — Firewall / IDS Monitoring	Skipped
VAPTORWIFI — Reserved for future implementation	Reserved
VAPTORAPP — Mobile Application Security Testing	Skipped
VAPTORDAST — DAST (Dynamic Application Security Testing)	Completed
VAPTORSAST — SAST (Static Application Security Testing)	Completed
VAPTORSHARK — Vaptor Network Shark	Completed
VAPTORAI — Vaptor AI Enhancement	Completed

Validation summary

Stage	Status	Targets	Scanners	Issues	Warnings
Overall	Warnings	21	VAPTORMSF, VAPTORSQL, VAPTORWEB	0	1
Vulnerability assessment	Warnings	21	VAPTORWEB	0	1
Penetration test	Valid	21	VAPTORMSF, VAPTORSQL	0	0

Notes

- VAPTORWEB: summary — timeouts=1, unreachable=0, empty_outputs=0
- VAPTORWEB: https://www.hackthissite.org — {"target": "https://www.hackthissite.org", "issue": "Command timed out after 2394s", "code": 124}
- [penetration_test] Scanner 'VAPTORSQL' completed and found 0 vulnerabilities on 4 target(s)

CMDB Summary

Inventory baseline derived from CMDB tables (MAC-canonical internal devices, IP-canonical external exposure).

Metric	Value
New devices (this scan)	1
New IPs (this scan)	1
IP changes (this scan)	0
Internal devices (total)	11

Metric	Value
Internal devices (seen this scan)	10
Internal devices (unknown vendor)	3
Internal current IPs	11
External IPs (total)	10
External IPs (seen this scan)	10

Top vendors (OUI)

Vendor	Count
Hon Hai Precision Ind. Co.,Ltd.	2
Apple, Inc.	1
CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.	1
DWnet Technologies(Suzhou) Corporation	1
HUAWEI TECHNOLOGIES CO.,LTD	1

Web Recon

Best-effort web content inventory (login hints, emails, paths). Some endpoints may block or return non-standard HTTP.

Metric	Value
Endpoints attempted	4
Endpoints reachable	4
Login hints	3
Emails found	0
Unique paths discovered	150

Endpoint	Status	Login	Emails	Paths	Notes
https://owasp.org/www-project-juice-shop/	200	Yes	0	21 (/assets/images/logo.png, /cdn-cgi/l/email-protection, /donate)	—
http://www.itsecgames.com/	200	No	0	16 (/bugs.htm, /download.htm, /downloads/bWAPP_intro.pdf)	—
https://pentest-ground.com/	200	Yes	0		—

Endpoint	Status	Login	Emails	Paths	Notes
				57 (/alpine-data.js, /documents/company/Q4_preview.pptx, /documents/company/Q4_report.csv)	
https://www.hackthissite.org/	200	Yes	0	57 (/CHANGELOG, /advertise, /articles/read/1154)	—

Enrichment

Domain Registration (WHOIS)

IP	Domain	Registrar	Expiration
137.74.187.100	hackthissite.org	Porkbun LLC	2026-08-10T15:01:25+00:00
137.74.187.101	hackthissite.org	Porkbun LLC	2026-08-10T15:01:25+00:00
137.74.187.102	hackthissite.org	Porkbun LLC	2026-08-10T15:01:25+00:00
137.74.187.103	hackthissite.org	Porkbun LLC	2026-08-10T15:01:25+00:00
137.74.187.104	hackthissite.org	Porkbun LLC	2026-08-10T15:01:25+00:00
178.79.134.182	LINODEUSERCONTENT.COM	MarkMonitor, Inc.	2026-12-18T18:38:04+00:00

IP	Domain	Registrar	Expiration
31.3.96.40	MMEBVBA.COM	GoDaddy.com, LLC	['2026-09-17T11:45:32+00:00', '2026-09-17T06:45:32+00:00']
44.228.249.3	AMAZONAWS.COM	MarkMonitor, Inc.	['2027-01-16T04:59:59+00:00', '2027-01-16T00:00:00+00:00']
44.238.29.244	AMAZONAWS.COM	MarkMonitor, Inc.	['2027-01-16T04:59:59+00:00', '2027-01-16T00:00:00+00:00']
81.169.145.156	rzone.de	—	—

BuiltWith Technology Profile

https://pentest-ground.com:

https://owasp-juice.shop/:

Category	Technologies
Cdn	CloudFlare
Javascript Frameworks	jQuery

https://www.hackthissite.org/:

Category	Technologies
Javascript Frameworks	jQuery

http://www.itsecgames.com/:

Category	Technologies
Font Scripts	Google Font API
Web Servers	Apache

http://www.vulnweb.com/:

Category	Technologies
Web Servers	Nginx

http://testhtml5.vulnweb.com:

Category	Technologies
Font Scripts	Google Font API
Javascript Frameworks	AngularJS, jQuery
Web Frameworks	Twitter Bootstrap

Category	Technologies
Web Servers	Nginx

http://testphp.vulnweb.com:

Category	Technologies
Editors	DreamWeaver
Web Servers	Nginx

http://testasp.vulnweb.com:

Category	Technologies
Editors	DreamWeaver
Operating Systems	Windows Server
Web Servers	IIS

http://testaspnet.vulnweb.com:

Category	Technologies
Operating Systems	Windows Server

Category	Technologies
Web Frameworks	Microsoft ASP.NET
Web Servers	IIS

BuiltWith data powered by external API enrichment.

Verification

Verification runs are scoped to discovered open TCP ports and use non-exploit auxiliary probes (service-aware).

Metric	Value
Status	completed
Checks attempted	23
Targets	completed=14, failed=0

Recon (VAPTORSHARK)

Metric	Value
Capture artifacts present	Yes
Artifact count	6

Metric	Value
Total artifact size (bytes)	315604477
Capture interface	eth0
Packets captured	1805849
Packets dropped	0
Drop rate	0.00%
PCAP files	1
PCAP total bytes	299886164
Capture timestamp	2026-03-11T15:32:17.146437Z

Note: Reports intentionally do not include intercepted content (e.g., URLs, credentials) to reduce sensitive-data exposure. Review capture artifacts directly when authorized.

MITM Artifacts (artifacts/mitm)

File	Kind	Bytes
pcap_summary.json	json	653
recon_observations.json	json	12659

File	Kind	Bytes
VAPTORARP20260311172652.log	log	15683109
VAPTORARP20260311172717.log	log	377
VAPTORCAP20260311172716_00001_20260311172717.pcapng	pcap	299886164
VAPTORPCAP20260311172716.log	log	21515

Visited domains (top)

Domain	Count
chatgpt.com	6455
go.trouter.skype.com	6318
teams.live.com	4673
www.msftconnecttest.com	4636
statics.teams.cdn.live.net	3442
dns.msftncsi.com	3128
epns.eset.com	2853
www.youtube.com	2673

Domain	Count
rr1---sn-u1woc5-5n.googlevideo.com	2580
ab.chatgpt.com	2484
us01.agent.edr.eset.systems	2247
pub-csm-dewc-02-t.trouter.skype.com	1579
edge.skype.com	1534
i1.c.eset.com	1530
pub-csm-plce-01-t.trouter.skype.com	1275
c.eset.com	1216
youtube-ui.l.google.com	1169
settings-win.data.microsoft.com	1136
pub-csm-dewc-03-t.trouter.skype.com	1020
kv601.prod.do.dsp.mp.microsoft.com	907
rr2---sn-8vq5jvh15-2gtl.googlevideo.com	762
connectivitycheck.gstatic.com	760

Domain	Count
r.edtd.eset.com	510
mobile.useinsider.com	510
tj6ypk3dmw6ezig56s4kzydds4.a.ecaserver.eset.com	510

Observed public IPs (top)

IP	Count
52.98.21.34	52651
72.144.120.145	33483
20.245.38.118	25432
13.107.213.56	11474
105.247.206.196	3821
104.44.23.71	3172
72.153.5.133	3038
142.251.47.14	2679
51.10.20.227	2552

IP	Count
72.145.35.119	2101
40.83.252.19	2070
52.123.128.14	2032
51.10.19.213	1950
104.44.44.167	1854
91.228.165.43	1845
104.44.50.206	1685
8.8.8.8	1538
91.228.166.14	1485
91.228.167.103	1419
142.251.216.14	1215
195.2.24.125	1163
45.197.87.56	1115
41.0.194.75	1077

IP	Count
62.115.122.139	975
193.118.38.245	852

Hostname enrichment (reverse DNS)

IP	Hostname	Count
105.247.206.196	vc-vb-105-247-206-196.ens.vodacom.co.za	3821
104.44.23.71	ae144-0.icr03.by21.ntwk.msn.net	3172
142.251.47.14	tzjnba-ar-in-f14.1e100.net	2679
104.44.44.167	ae77-0.ier02.cpt30.ntwk.msn.net	1854
91.228.165.43	h1-c03-s.eset.com	1845
104.44.50.206	ae25-0.icr02.cpt20.ntwk.msn.net	1685
8.8.8.8	dns.google	1538
91.228.166.14	um02.eset.com	1485
91.228.167.103	h3-c04-b.eset.com	1419
142.251.216.14	lcjnbi-af-in-f14.1e100.net	1215

IP	Hostname	Count
195.2.24.125	ae1-xcr1.ltw.cw.net	1163
41.0.194.75	vc-vb-41-0-194-75.ens.vodacom.co.za	1077
62.115.122.139	ffm-bb2-link.ip.twelve99.net	975
154.54.75.97	be7944.ccr22.muc03.atlas.cogentco.com	710
62.115.133.239	prs-bb2-link.ip.twelve99.net	691

Potential sensitive transmissions (signals only)

Signal	Count
http_post	2
http_authorization_header	1

SAST - Static Application Security Testing

Source path: /home/***/vaptor/be/tests/VulnerableApp-master/VulnerableApp-master

Scan timestamp: 2026-03-11T15:26:44.829359

Total findings: 50

Tool Results

Tool	Status	Findings
bearer	completed	50
bandit	completed	0
gitleaks	completed	0

VAPTORSAST Code Security Findings (Bearer)

Severity	Finding	CWE	Location
CRITICAL	Usage of hard-coded secret	798	...rg/sasanlabs/service/vulnerability/jwt/bean/JWTUtils.java:44
CRITICAL	Usage of hard-coded secret	798	...rg/sasanlabs/service/vulnerability/jwt/bean/JWTUtils.java:48
CRITICAL	Unsanitized user input in XML External Entity	611	...sasanlabs/service/vulnerability/xxe/XXEVulnerability.java:75
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...nerability/staticResources/LEVEL_1/SampleVulnerability.js:22
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...es/static/templates/CommandInjection/LEVEL_1/CI_Level1.js:14

Severity	Finding	CWE	Location
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...es/CryptographicFailures/LEVEL_1/CryptographicFailures.js:8
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...es/CryptographicFailures/LEVEL_1/CryptographicFailures.js:44
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...es/CryptographicFailures/LEVEL_1/CryptographicFailures.js:47
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...dSQLInjectionVulnerability/LEVEL_1/SQLInjection_Level1.js:17
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...s/static/templates/JWTVulnerability/LEVEL_1/JWT_Level1.js:25
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...ates/JWTVulnerability/LEVEL_13/HeaderInjection_Level13.js:24
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...ates/JWTVulnerability/LEVEL_13/HeaderInjection_Level13.js:30
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...s/static/templates/JWTVulnerability/LEVEL_2/JWT_Level2.js:24
HIGH		79	

Severity	Finding	CWE	Location
	Unsanitized user input in dynamic HTML insertion (XSS)		...s/static/templates/JWTVulnerability/LEVEL_2/JWT_Level2.js:30
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...es/static/templates/JWTVulnerability/LEVEL_7/JWT_Level.js:35
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...es/static/templates/JWTVulnerability/LEVEL_7/JWT_Level.js:41
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...s/static/templates/PathTraversal/LEVEL_1/PathTraversal.js:35
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...sistentXSSInHTMLTagVulnerability/LEVEL_1/PersistentXSS.js:17
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...sistentXSSInHTMLTagVulnerability/LEVEL_1/PersistentXSS.js:22
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...ources/static/templates/SSRFVulnerability/LEVEL_1/SSRF.js:24
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...plates/SampleVulnerability/LEVEL_1/SampleVulnerability.js:22
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...dSQLInjectionVulnerability/LEVEL_1/SQLInjection_Level1.js:16

Severity	Finding	CWE	Location
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...ic/templates/UnrestrictedFileUpload/LEVEL_1/FileUpload.js:14
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...rces/static/templates/XSSInImgTagAttribute/LEVEL_1/XSS.js:16
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...s/static/templates/XSSWithHtmlTagInjection/LEVEL_1/XSS.js:15
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	.../templates/XSSWithNullBytesImgTagAttribute/LEVEL_1/XSS.js:14
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...esources/static/templates/XXEVulnerability/LEVEL_1/XXE.js:18
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...esources/static/templates/XXEVulnerability/LEVEL_1/XXE.js:22
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...esources/static/templates/XXEVulnerability/LEVEL_1/XXE.js:26
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...esources/static/templates/XXEVulnerability/LEVEL_1/XXE.js:30
HIGH		79	

Severity	Finding	CWE	Location
	Unsanitized user input in dynamic HTML insertion (XSS)		...esources/static/templates/XXEVulnerability/LEVEL_1/XXE.js:34
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	...esources/static/templates/XXEVulnerability/LEVEL_1/XXE.js:78
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	src/main/resources/static/vulnerableApp.js:57
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	src/main/resources/static/vulnerableApp.js:71
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	src/main/resources/static/vulnerableApp.js:107
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	src/main/resources/static/vulnerableApp.js:162
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	src/main/resources/static/vulnerableApp.js:168
HIGH	Unsanitized user input in dynamic HTML insertion (XSS)	79	src/main/resources/static/vulnerableApp.js:312
MEDIUM	Missing HTTP Only option in cookie configuration	1004	...nlabs/service/vulnerability/idor/IDORLoginController.java:50

Severity	Finding	CWE	Location
MEDIUM	Missing Secure option in cookie configuration	614	...nlabs/service/vulnerability/idor/IDORLoginController.java:50
MEDIUM	Usage of insufficient random value	330	...vice/vulnerability/fileupload/UnrestrictedFileUpload.java:53
MEDIUM	Observable Timing Discrepancy	208	...tographicFailures/CryptographicFailuresVulnerability.java:90
MEDIUM	Observable Timing Discrepancy	208	...tographicFailures/CryptographicFailuresVulnerability.java:132
MEDIUM	Observable Timing Discrepancy	208	...tographicFailures/CryptographicFailuresVulnerability.java:175
MEDIUM	Observable Timing Discrepancy	208	...tographicFailures/CryptographicFailuresVulnerability.java:215
MEDIUM	Observable Timing Discrepancy	208	...tographicFailures/CryptographicFailuresVulnerability.java:266
MEDIUM	Observable Timing Discrepancy	208	...asanlabs/service/vulnerability/jwt/impl/JWTValidator.java:52
MEDIUM		501	

Severity	Finding	CWE	Location
	Usage of trusted and untrusted data inside the same data structure		...nlabs/service/vulnerability/idor/IDORLoginController.java:36
LOW	Leakage of information in logger message	532	...s/static/templates/JWTVulnerability/LEVEL_1/JWT_Level1.js:14
LOW	Leakage of information in logger message	532	...s/static/templates/JWTVulnerability/LEVEL_1/JWT_Level1.js:15

50 Bearer findings. Ref: artifacts/sast/bearer_results.json

Note: SAST results provide static code analysis findings. Review detailed artifacts under artifacts/sast/ for remediation guidance.

DAST - Dynamic Application Security Testing

Targets scanned: 28

Scan timestamp: 2026-03-11T15:27:09.613708

Total findings: 1

Tool Results

Tool	Status	Targets	Findings
VAPTORRECON	completed	28	1

Tool	Status	Targets	Findings
VAPTORDAST	completed	28	0

Nuclei Vulnerability Findings

Severity	Finding	Target	CVE	CVSS	CWE
HIGH	Redis Server - Unauthenticated Access	pentest-ground.com:6379:6379	—	7.2	cwe-306

Showing all 1 Nuclei findings. Review full results in artifacts/dast/nuclei_results.json

Note: DAST results provide dynamic vulnerability assessment findings. Review detailed artifacts under artifacts/dast/ for specific CVE/misconfig details.

3) Technical Details (Per Asset)

Asset: VAPTOR001A0001

Asset fingerprint

Field	Value
MAC Address	N/A
IP	178.79.134.182

Field	Value
Hostname	178-79-134-182.ip.linodeusercontent.com
OS fingerprint	Linux 4.15 - 5.19

Open ports

Proto	Port	Service	Risk
tcp	4445	upnotifyp	—

Watchdog mini-recap

- **Exposed:** 1 open port(s), 0 high-risk service(s).
  Top: tcp/4445 upnotifyp
- **Vulnerable:** 32 finding(s) (Critical 0, High 0, Medium 10).
- **Evidence:** 32/32 finding(s) include evidence snippets.
- **Remediation:** 31/32 finding(s) include remediation guidance.
  Suggested: Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.; Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.

Vulnerabilities (32)

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

Severity	Title	CVE	CVSS
MEDIUM	CSP: style-src unsafe-inline	—	5.0
MEDIUM	CSP: Wildcard Directive	—	5.0
MEDIUM	CSP: Failure to Define Directive with No Fallback	—	5.0
MEDIUM	Application Error Disclosure	—	5.0
MEDIUM	Vulnerable JS Library	—	5.0
MEDIUM	Sub Resource Integrity Attribute Missing	—	5.0
MEDIUM	Missing Anti-clickjacking Header	—	5.0
MEDIUM	Cross-Domain Misconfiguration	—	5.0
MEDIUM	Content Security Policy (CSP) Header Not Set	—	5.0
MEDIUM	Absence of Anti-CSRF Tokens	—	5.0
LOW	Timestamp Disclosure - Unix	—	2.5
LOW	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	—	2.5

Severity	Title	CVE	CVSS
LOW	Private IP Disclosure	—	2.5
LOW	Information Disclosure - Debug Error Messages	—	2.5
LOW	In Page Banner Information Leak	—	2.5
LOW	Server Leaks Version Information via "Server" HTTP Response Header Field	—	2.5
LOW	Secure Pages Include Mixed Content	—	2.5
LOW	Cross-Domain JavaScript Source File Inclusion	—	2.5
LOW	Cookie No HttpOnly Flag	—	2.5
LOW	X-Content-Type-Options Header Missing	—	2.5
LOW	Strict-Transport-Security Header Not Set	—	2.5
LOW	Cookie without SameSite Attribute	—	2.5
LOW	Cookie Without Secure Flag	—	2.5
INFO	User Agent Fuzzer	—	0.0
INFO	Information Disclosure - Sensitive Information in URL	—	0.0
INFO	Cookie Poisoning	—	0.0

Severity	Title	CVE	CVSS
INFO	User Controllable HTML Element Attribute (Potential XSS)	—	0.0
INFO	Information Disclosure - Suspicious Comments	—	0.0
INFO	Session Management Response Identified	—	0.0
INFO	Re-examine Cache-control Directives	—	0.0
INFO	Modern Web Application	—	0.0
INFO	Authentication Request Identified	—	0.0

Finding notes: CSP: style-src unsafe-inline

Description

```
Content Security Policy (CSP) is an added layer of security that helps to detect and
mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting
(XSS), and data injection attacks. These attacks are used for everything from data theft
to site defacement or distribution of malware. CSP provides a set of standard HTTP
headers that allow website owners to declare approved sources of content that browsers
should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames,
fonts, images and embeddable objects such as Java applets, ActiveX, audio and video
files.
```

Evidence

```
Target: https://pentest-ground.com:4280/vulnerabilities/csp/ | Finding: CSP: style-src
unsafe-inline | Reported Severity: medium
```

Remediation

```
Ensure that your web server, application server, load balancer, etc. is properly
configured to set the Content-Security-Policy header.
```

Remediation (detailed)

Effort: 30 minutes - 1 hour
Business impact: MEDIUM - Reduces attack surface and provides defense-in-depth

1. Add Content-Security-Policy header
2. Add X-Frame-Options header to prevent clickjacking
3. Add X-Content-Type-Options: nosniff
4. Add Strict-Transport-Security (HSTS) for HTTPS sites
5. Add X-XSS-Protection for legacy browser support
6. Remove Server header to reduce information disclosure

Verification:

- Use curl to check headers: curl -I https://example.com
- Use online tools like securityheaders.com
- Check with browser developer tools (Network tab)
- Use automated scanners to verify implementation

References:

- https://www.w3.org/TR/CSP/
- https://caniuse.com/#search=content+security+policy
- https://content-security-policy.com/
- https://github.com/HtmlUnit/htmlunit-csp
- https://web.dev/articles/csp#resource-options
- https://owasp.org/www-project-secure-headers/
- https://securityheaders.com/
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers

Finding notes: CSP: Wildcard Directive

Description

```
Content Security Policy (CSP) is an added layer of security that helps to detect and
mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting
(XSS), and data injection attacks. These attacks are used for everything from data theft
to site defacement or distribution of malware. CSP provides a set of standard HTTP
headers that allow website owners to declare approved sources of content that browsers
should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames,
fonts, images and embeddable objects such as Java applets, ActiveX, audio and video
files.
```

Evidence

```
Target: https://pentest-ground.com:4280/vulnerabilities/csp/ | Finding: CSP: Wildcard
Directive | Reported Severity: medium
```

Remediation

```
Ensure that your web server, application server, load balancer, etc. is properly
configured to set the Content-Security-Policy header.
```

Remediation (detailed)

Effort: 30 minutes - 1 hour
Business impact: MEDIUM - Reduces attack surface and provides defense-in-depth

1. Add Content-Security-Policy header
2. Add X-Frame-Options header to prevent clickjacking
3. Add X-Content-Type-Options: nosniff
4. Add Strict-Transport-Security (HSTS) for HTTPS sites
5. Add X-XSS-Protection for legacy browser support
6. Remove Server header to reduce information disclosure

Verification:

- Use curl to check headers: curl -I https://example.com
- Use online tools like securityheaders.com
- Check with browser developer tools (Network tab)
- Use automated scanners to verify implementation

References:

- https://www.w3.org/TR/CSP/
- https://caniuse.com/#search=content+security+policy
- https://content-security-policy.com/
- https://github.com/HtmlUnit/htmlunit-csp
- https://web.dev/articles/csp#resource-options
- https://owasp.org/www-project-secure-headers/
- https://securityheaders.com/
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers

Finding notes: CSP: Failure to Define Directive with No Fallback

Description

```
The Content Security Policy fails to define one of the directives that has no fallback.
Missing/excluding them is the same as allowing anything.
```

Evidence

```
Target: https://pentest-ground.com:4280/vulnerabilities/csp/ | Finding: CSP: Failure to
Define Directive with No Fallback | Reported Severity: medium
```

Remediation

```
Ensure that your web server, application server, load balancer, etc. is properly
configured to set the Content-Security-Policy header.
```

Remediation (detailed)

Effort: 30 minutes - 1 hour
Business impact: MEDIUM - Reduces attack surface and provides defense-in-depth

1. Add Content-Security-Policy header
2. Add X-Frame-Options header to prevent clickjacking
3. Add X-Content-Type-Options: nosniff
4. Add Strict-Transport-Security (HSTS) for HTTPS sites
5. Add X-XSS-Protection for legacy browser support
6. Remove Server header to reduce information disclosure

Verification:

- Use curl to check headers: curl -I https://example.com
- Use online tools like securityheaders.com
- Check with browser developer tools (Network tab)
- Use automated scanners to verify implementation

References:

- https://www.w3.org/TR/CSP/
- https://caniuse.com/#search=content+security+policy
- https://content-security-policy.com/
- https://github.com/HtmlUnit/htmlunit-csp
- https://web.dev/articles/csp#resource-options
- https://owasp.org/www-project-secure-headers/
- https://securityheaders.com/

- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers

Finding notes: Application Error Disclosure

Description

```
This page contains an error/warning message that may disclose sensitive information like
the location of the file that produced the unhandled exception. This information can be
used to launch further attacks against the web application. The alert could be a false
positive if the error message is found inside a documentation page.
```

Evidence

```
Target: https://pentest-ground.com:4280/README.ar.md | Finding: Application Error
Disclosure | Reported Severity: medium
```

Remediation

```
Review the source code of this page. Implement custom error pages. Consider implementing
a mechanism to provide a unique error reference/identifier to the client (browser) while
logging the details on the server side and not exposing them to the user.
```

Remediation (detailed)

Effort: Variable

Business impact: Depends on vulnerability context

1. Review the source code of this page. Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user.

Finding notes: Vulnerable JS Library

Description

```
The identified library appears to be vulnerable.
```

Evidence

```
Target: https://pentest-ground.com:81/static/js/bootstrap.js | Finding: Vulnerable JS
Library | Reported Severity: medium
```

Remediation

```
Upgrade to the latest version of the affected library.
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. Upgrade to the latest version of the affected library.

References:

- https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/

Finding notes: Sub Resource Integrity Attribute Missing

Description

```
The integrity attribute is missing on a script or link tag served by an external server.
The integrity tag prevents an attacker who have gained access to this server from
injecting a malicious content.
```

Evidence

```
Target: https://pentest-ground.com:81/ | Finding: Sub Resource Integrity Attribute
Missing | Reported Severity: medium
```

Remediation

```
Provide a valid integrity attribute to the tag.
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. Provide a valid integrity attribute to the tag.

References:

- https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity

Finding notes: Missing Anti-clickjacking Header

Description

```
The response does not protect against 'ClickJacking' attacks. It should include either
Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
```

Evidence

```
Target: https://pentest-ground.com:81/ | Finding: Missing Anti-clickjacking Header |
Reported Severity: medium
```

Remediation

```
Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers.
Ensure one of them is set on all web pages returned by your site/app.If you expect the
page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll
want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should
use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors"
directive.
```

Remediation (detailed)

Effort: Variable

Business impact: Depends on vulnerability context

1. Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security...

References:

- https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Finding notes: Cross-Domain Misconfiguration

Description

```
Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS)
misconfiguration on the web server.
```

Evidence

```
Target: https://pentest-ground.com:81/ | Finding: Cross-Domain Misconfiguration |
Reported Severity: medium
```

Remediation

```
Ensure that sensitive data is not available in an unauthenticated manner (using IP
address white-listing, for instance).Configure the "Access-Control-Allow-Origin" HTTP
header to a more restrictive set of domains, or remove all CORS headers entirely, to
```

```
allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive
manner.
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance).Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

References:

- https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

Finding notes: Content Security Policy (CSP) Header Not Set

Description

```
Content Security Policy (CSP) is an added layer of security that helps to detect and
mitigate certain types of attacks, including Cross Site Scripting (XSS) and data
injection attacks. These attacks are used for everything from data theft to site
defacement or distribution of malware. CSP provides a set of standard HTTP headers that
allow website owners to declare approved sources of content that browsers should be
```

```
allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts,
images and embeddable objects such as Java applets, ActiveX, audio and video files.
```

Evidence

```
Target: https://pentest-ground.com:7001/console/login/LoginForm.jsp | Finding: Content
Security Policy (CSP) Header Not Set | Reported Severity: medium
```

Remediation

```
Ensure that your web server, application server, load balancer, etc. is configured to set
the Content-Security-Policy header.
```

Remediation (detailed)

Effort: 30 minutes - 1 hour
Business impact: MEDIUM - Reduces attack surface and provides defense-in-depth

1. Add Content-Security-Policy header
2. Add X-Frame-Options header to prevent clickjacking
3. Add X-Content-Type-Options: nosniff
4. Add Strict-Transport-Security (HSTS) for HTTPS sites
5. Add X-XSS-Protection for legacy browser support
6. Remove Server header to reduce information disclosure

Verification:

- Use curl to check headers: curl -I https://example.com
- Use online tools like securityheaders.com

- Check with browser developer tools (Network tab)
- Use automated scanners to verify implementation

References:

- https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
- https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
- https://www.w3.org/TR/CSP/
- https://w3c.github.io/webappsec-csp/
- https://web.dev/articles/csp
- https://caniuse.com/#feat=contentsecuritypolicy
- https://content-security-policy.com/
- https://owasp.org/www-project-secure-headers/
- https://securityheaders.com/
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers

Finding notes: Absence of Anti-CSRF Tokens

Description

```
No Anti-CSRF tokens were found in a HTML submission form.A cross-site request forgery is
an attack that involves forcing a victim to send an HTTP request to a target destination
without their knowledge or intent in order to perform an action as the victim. The
underlying cause is application functionality using predictable URL/form actions in a
repeatable way. The nature of the attack is that CSRF exploits the trust that a web site
has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user
```

```
has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can
be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session
riding, confused deputy, and sea surf.CSRF attacks are effective in a number of
situations, including:    * The victim has an active session on the target site.    * The
victim is authenticated via HTTP auth on the target site.    * The victim is on the same
local network as the target site.CSRF has primarily been used to perform an action
against a target site using the victim's privileges, but recent techniques have been
discovered to disclose information by gaining access to the response. The risk of
information disclosure is dramatically increased when the target site is vulnerable to
XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate
within the bounds of the same-origin policy.
```

Evidence

```
Target: https://pentest-ground.com:7001/console/login/LoginForm.jsp | Finding: Absence of
Anti-CSRF Tokens | Reported Severity: medium
```

Remediation

```
Phase: Architecture and DesignUse a vetted library or framework that does not allow this
weakness to occur or provides constructs that make this weakness easier to avoid.For
example, use anti-CSRF packages such as the OWASP CSRFGuard.Phase: ImplementationEnsure
that your application is free of cross-site scripting issues, because most CSRF defenses
can be bypassed using attacker-controlled script.Phase: Architecture and DesignGenerate a
unique nonce for each form, place the nonce into the form, and verify the nonce upon
receipt of the form. Be sure that the nonce is not predictable (CWE-330).Note that this
```

```
can be bypassed using XSS.Identify especially dangerous operations. When the user
performs a dangerous operation, send a separate confirmation request to ensure that the
user intended to perform that operation.Note that this can be bypassed using XSS.Use the
ESAPI Session Management control.This control includes a component for CSRF.Do not use
the GET method for any request that triggers a state change.Phase: ImplementationCheck
the HTTP Referer header to see if the request originated from an expected page. This
could break legitimate functionality, because users or proxies may have disabled sending
the Referer for privacy reasons.
```

Remediation (detailed)

Effort: 4-8 hours
Business impact: MEDIUM - Prevents unauthorized actions on behalf of authenticated users

1. Implement CSRF tokens for all state-changing operations
2. Use SameSite cookie attribute
3. Verify Origin and Referer headers
4. Implement custom request headers for AJAX calls
5. Use double-submit cookie pattern

Verification:

- Remove CSRF token and submit form
- Submit form from different domain
- Check if tokens are validated server-side
- Verify SameSite cookie attribute is set

References:

- https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html
- https://cwe.mitre.org/data/definitions/352.html

Finding notes: Timestamp Disclosure - Unix

Description

```
A timestamp was disclosed by the application/web server. - Unix
```

Evidence

```
Target: https://pentest-ground.com:4280/vulnerabilities/javascript/ | Finding: Timestamp
Disclosure - Unix | Reported Severity: low
```

Remediation

```
Manually confirm that the timestamp data is not sensitive, and that the data cannot be
aggregated to disclose exploitable patterns.
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.

References:

- https://cwe.mitre.org/data/definitions/200.html

Finding notes: Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)

Description

```
The web/application server is leaking information via one or more "X-Powered-By" HTTP
response headers. Access to such information may facilitate attackers identifying other
frameworks/components your web application is reliant upon and the vulnerabilities such
components may be subject to.
```

Evidence

```
Target: https://pentest-ground.com:4280/ | Finding: Server Leaks Information via "X-
Powered-By" HTTP Response Header Field(s) | Reported Severity: low
```

Remediation

```
Ensure that your web server, application server, load balancer, etc. is configured to
suppress "X-Powered-By" headers.
```

Remediation (detailed)

Effort: Variable

Business impact: Depends on vulnerability context

1. Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.

References:

- https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework
- https://www.troyhunt.com/shhh-dont-let-your-response-headers/

Asset: VAPTOR001A0002

Asset fingerprint

Field	Value
MAC Address	N/A
IP	81.169.145.156
Hostname	w9c.rzone.de
OS fingerprint	OpenBSD 5.8

Open ports

Proto	Port	Service	Risk
tcp	21	ftp	HIGH
tcp	80	http	HIGH
tcp	443	https	MEDIUM
tcp	8080	http-proxy	HIGH

High-risk port notes (VaptorAI / Intel DB)

Port exposure notes (VaptorAI): tcp/21 ftp [HIGH]

Narrative

```
# Port Exposure: tcp/21

## Summary
An Internet-accessible service was detected on tcp/21. Exposed management and remote-
access ports are frequently targeted for credential attacks and exploitation.

## Why this matters (Risk)
- Increases attack surface and brute-force exposure
- May permit remote code execution if vulnerable and unpatched
- Often enables lateral movement once credentials are obtained
```

```
## Recommended actions (Remediation)
- Restrict access (VPN/jump host/allowlist)
- Enforce MFA and strong authentication policies
- Patch the exposed service and disable legacy/insecure options

## Evidence
- Observed open: tcp/21
```

Port exposure notes: tcp/21 ftp [HIGH]

Why this matters Legacy file transfer protocol with weak security controls, cleartext credentials

Common attacks Brute Force, Anonymous Login, Bounce Attack, Cleartext Credentials, Directory Traversal

Notable CVEsCVE-2015-3306, CVE-2011-2523, CVE-2010-4221

Recommended action Replace with SFTP or FTPS. If required, disable anonymous access. Use strong passwords. Restrict by IP.

Port exposure notes (VaptorAI): tcp/80 http [HIGH]

Narrative

```
# Port Exposure: tcp/80

## Summary
An Internet-accessible service was detected on tcp/80. Exposed management and remote-
```

```
access ports are frequently targeted for credential attacks and exploitation.

## Why this matters (Risk)
- Increases attack surface and brute-force exposure
- May permit remote code execution if vulnerable and unpatched
- Often enables lateral movement once credentials are obtained

## Recommended actions (Remediation)
- Restrict access (VPN/jump host/allowlist)
- Enforce MFA and strong authentication policies
- Patch the exposed service and disable legacy/insecure options

## Evidence
- Observed open: tcp/80
```

Port exposure notes: tcp/80 http [HIGH]

Why this matters Unencrypted web traffic; web application vulnerabilities, MitM attacks

Common attacksSQL Injection, XSS, CSRF, Directory Traversal, Man-in-the-Middle, Session Hijacking

Notable CVEsCVE-2021-44228, CVE-2017-5638, CVE-2014-0160

Recommended action Redirect all traffic to HTTPS (port 443). Disable HTTP or use only for redirect. Implement HSTS headers.

Port exposure notes (VaptorAI): tcp/8080 http-proxy [HIGH]

Narrative

```
# Port Exposure: tcp/8080

## Summary
An Internet-accessible service was detected on tcp/8080. Exposed management and remote-
access ports are frequently targeted for credential attacks and exploitation.

## Why this matters (Risk)
- Increases attack surface and brute-force exposure
- May permit remote code execution if vulnerable and unpatched
- Often enables lateral movement once credentials are obtained

## Recommended actions (Remediation)
- Restrict access (VPN/jump host/allowlist)
- Enforce MFA and strong authentication policies
- Patch the exposed service and disable legacy/insecure options

## Evidence
- Observed open: tcp/8080
```

Port exposure notes: tcp/8080 http-proxy [HIGH]

Why this matters Alternate HTTP port; web apps, proxies, same risks as port 80

Common attacks Web App Vulnerabilities, Proxy Abuse, Admin Panel Exposure

Notable CVEsCVE-2021-44228, CVE-2017-5638

Recommended action Redirect to HTTPS. Same hardening as port 80. Disable or secure admin interfaces.

Watchdog mini-recap

- **Exposed:** 4 open port(s), 3 high-risk service(s).
  Top: tcp/21 ftp [HIGH]; tcp/80 http [HIGH]; tcp/443 https [MEDIUM]
- **Vulnerable:** 13 finding(s) (Critical 0, High 0, Medium 6).
- **Evidence:** 13/13 finding(s) include evidence snippets.
- **Remediation:** 12/13 finding(s) include remediation guidance.
  Suggested: Provide a valid integrity attribute to the tag.; Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance).Configure the "Access-Control-Allow-Origin" HTTP header t...

Vulnerabilities (13)

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

Severity	Title	CVE	CVSS
MEDIUM	Sub Resource Integrity Attribute Missing	—	5.0

Severity	Title	CVE	CVSS
MEDIUM	Cross-Domain Misconfiguration	—	5.0
MEDIUM	CSP: style-src unsafe-inline	—	5.0
MEDIUM	CSP: script-src unsafe-inline	—	5.0
MEDIUM	CSP: script-src unsafe-eval	—	5.0
MEDIUM	CSP: Failure to Define Directive with No Fallback	—	5.0
LOW	Strict-Transport-Security Header Not Set	—	2.5
LOW	Cross-Domain JavaScript Source File Inclusion	—	2.5
INFO	User Agent Fuzzer	—	0.0
INFO	Retrieved from Cache	—	0.0
INFO	Re-examine Cache-control Directives	—	0.0
INFO	Modern Web Application	—	0.0
INFO	Information Disclosure - Suspicious Comments	—	0.0

Finding notes: Sub Resource Integrity Attribute Missing

Description

```
The integrity attribute is missing on a script or link tag served by an external server.
The integrity tag prevents an attacker who have gained access to this server from
injecting a malicious content.
```

Evidence

```
Target: https://owasp-juice.shop | Finding: Sub Resource Integrity Attribute Missing |
Reported Severity: medium
```

Remediation

```
Provide a valid integrity attribute to the tag.
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. Provide a valid integrity attribute to the tag.

References:

- https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity

Finding notes: Cross-Domain Misconfiguration

Description

```
Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS)
misconfiguration on the web server.
```

Evidence

```
Target: https://owasp-juice.shop | Finding: Cross-Domain Misconfiguration | Reported
Severity: medium
```

Remediation

```
Ensure that sensitive data is not available in an unauthenticated manner (using IP
address white-listing, for instance).Configure the "Access-Control-Allow-Origin" HTTP
header to a more restrictive set of domains, or remove all CORS headers entirely, to
allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive
manner.
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance).Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

References:

- https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

Finding notes: CSP: style-src unsafe-inline

Description

```
Content Security Policy (CSP) is an added layer of security that helps to detect and
mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting
(XSS), and data injection attacks. These attacks are used for everything from data theft
to site defacement or distribution of malware. CSP provides a set of standard HTTP
headers that allow website owners to declare approved sources of content that browsers
should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames,
fonts, images and embeddable objects such as Java applets, ActiveX, audio and video
files.
```

Evidence

```
Target: https://owasp-juice.shop | Finding: CSP: style-src unsafe-inline | Reported
Severity: medium
```

Remediation

```
Ensure that your web server, application server, load balancer, etc. is properly
configured to set the Content-Security-Policy header.
```

Remediation (detailed)

Effort: 30 minutes - 1 hour
Business impact: MEDIUM - Reduces attack surface and provides defense-in-depth

1. Add Content-Security-Policy header
2. Add X-Frame-Options header to prevent clickjacking
3. Add X-Content-Type-Options: nosniff
4. Add Strict-Transport-Security (HSTS) for HTTPS sites
5. Add X-XSS-Protection for legacy browser support
6. Remove Server header to reduce information disclosure

Verification:

- Use curl to check headers: curl -I https://example.com
- Use online tools like securityheaders.com
- Check with browser developer tools (Network tab)
- Use automated scanners to verify implementation

References:

- https://www.w3.org/TR/CSP/
- https://caniuse.com/#search=content+security+policy
- https://content-security-policy.com/
- https://github.com/HtmlUnit/htmlunit-csp
- https://web.dev/articles/csp#resource-options
- https://owasp.org/www-project-secure-headers/
- https://securityheaders.com/

- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers

Finding notes: CSP: script-src unsafe-inline

Description

```
Content Security Policy (CSP) is an added layer of security that helps to detect and
mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting
(XSS), and data injection attacks. These attacks are used for everything from data theft
to site defacement or distribution of malware. CSP provides a set of standard HTTP
headers that allow website owners to declare approved sources of content that browsers
should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames,
fonts, images and embeddable objects such as Java applets, ActiveX, audio and video
files.
```

Evidence

```
Target: https://owasp-juice.shop | Finding: CSP: script-src unsafe-inline | Reported
Severity: medium
```

Remediation

```
Ensure that your web server, application server, load balancer, etc. is properly
configured to set the Content-Security-Policy header.
```

Remediation (detailed)

Effort: 30 minutes - 1 hour

Business impact: MEDIUM - Reduces attack surface and provides defense-in-depth

1. Add Content-Security-Policy header
2. Add X-Frame-Options header to prevent clickjacking
3. Add X-Content-Type-Options: nosniff
4. Add Strict-Transport-Security (HSTS) for HTTPS sites
5. Add X-XSS-Protection for legacy browser support
6. Remove Server header to reduce information disclosure

Verification:

- Use curl to check headers: curl -I https://example.com
- Use online tools like securityheaders.com
- Check with browser developer tools (Network tab)
- Use automated scanners to verify implementation

References:

- https://www.w3.org/TR/CSP/
- https://caniuse.com/#search=content+security+policy
- https://content-security-policy.com/
- https://github.com/HtmlUnit/htmlunit-csp
- https://web.dev/articles/csp#resource-options
- https://owasp.org/www-project-secure-headers/
- https://securityheaders.com/
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers

Finding notes: CSP: script-src unsafe-eval

Description

```
Content Security Policy (CSP) is an added layer of security that helps to detect and
mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting
(XSS), and data injection attacks. These attacks are used for everything from data theft
to site defacement or distribution of malware. CSP provides a set of standard HTTP
headers that allow website owners to declare approved sources of content that browsers
should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames,
fonts, images and embeddable objects such as Java applets, ActiveX, audio and video
files.
```

Evidence

```
Target: https://owasp-juice.shop | Finding: CSP: script-src unsafe-eval | Reported
Severity: medium
```

Remediation

```
Ensure that your web server, application server, load balancer, etc. is properly
configured to set the Content-Security-Policy header.
```

Remediation (detailed)

Effort: 30 minutes - 1 hour
Business impact: MEDIUM - Reduces attack surface and provides defense-in-depth

1. Add Content-Security-Policy header

2. Add X-Frame-Options header to prevent clickjacking
3. Add X-Content-Type-Options: nosniff
4. Add Strict-Transport-Security (HSTS) for HTTPS sites
5. Add X-XSS-Protection for legacy browser support
6. Remove Server header to reduce information disclosure

Verification:

- Use curl to check headers: curl -I https://example.com
- Use online tools like securityheaders.com
- Check with browser developer tools (Network tab)
- Use automated scanners to verify implementation

References:

- https://www.w3.org/TR/CSP/
- https://caniuse.com/#search=content+security+policy
- https://content-security-policy.com/
- https://github.com/HtmlUnit/htmlunit-csp
- https://web.dev/articles/csp#resource-options
- https://owasp.org/www-project-secure-headers/
- https://securityheaders.com/
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers

Finding notes: CSP: Failure to Define Directive with No Fallback

Description

```
The Content Security Policy fails to define one of the directives that has no fallback.
Missing/excluding them is the same as allowing anything.
```

Evidence

```
Target: https://owasp-juice.shop | Finding: CSP: Failure to Define Directive with No
Fallback | Reported Severity: medium
```

Remediation

```
Ensure that your web server, application server, load balancer, etc. is properly
configured to set the Content-Security-Policy header.
```

Remediation (detailed)

Effort: 30 minutes - 1 hour
Business impact: MEDIUM - Reduces attack surface and provides defense-in-depth

1. Add Content-Security-Policy header
2. Add X-Frame-Options header to prevent clickjacking
3. Add X-Content-Type-Options: nosniff
4. Add Strict-Transport-Security (HSTS) for HTTPS sites
5. Add X-XSS-Protection for legacy browser support
6. Remove Server header to reduce information disclosure

Verification:

- Use curl to check headers: curl -I https://example.com
- Use online tools like securityheaders.com

- Check with browser developer tools (Network tab)
- Use automated scanners to verify implementation

References:

- https://www.w3.org/TR/CSP/
- https://caniuse.com/#search=content+security+policy
- https://content-security-policy.com/
- https://github.com/HtmlUnit/htmlunit-csp
- https://web.dev/articles/csp#resource-options
- https://owasp.org/www-project-secure-headers/
- https://securityheaders.com/
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers

Finding notes: Strict-Transport-Security Header Not Set

Description

```
HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web
server declares that complying user agents (such as a web browser) are to interact with
it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF
standards track protocol and is specified in RFC 6797.
```

Evidence

```
Target: https://owasp-juice.shop | Finding: Strict-Transport-Security Header Not Set |
Reported Severity: low
```

Remediation

```
Ensure that your web server, application server, load balancer, etc. is configured to
enforce Strict-Transport-Security.
```

Remediation (detailed)

Effort: 30 minutes - 1 hour
Business impact: MEDIUM - Reduces attack surface and provides defense-in-depth

1. Add Content-Security-Policy header
2. Add X-Frame-Options header to prevent clickjacking
3. Add X-Content-Type-Options: nosniff
4. Add Strict-Transport-Security (HSTS) for HTTPS sites
5. Add X-XSS-Protection for legacy browser support
6. Remove Server header to reduce information disclosure

Verification:

- Use curl to check headers: curl -I https://example.com
- Use online tools like securityheaders.com
- Check with browser developer tools (Network tab)
- Use automated scanners to verify implementation

References:

- https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html
- https://owasp.org/www-community/Security_Headers
- https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security
- https://caniuse.com/stricttransportsecurity
- https://datatracker.ietf.org/doc/html/rfc6797
- https://owasp.org/www-project-secure-headers/
- https://securityheaders.com/
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers

Finding notes: Cross-Domain JavaScript Source File Inclusion

Description

```
The page includes one or more script files from a third-party domain.
```

Evidence

```
Target: https://owasp-juice.shop | Finding: Cross-Domain JavaScript Source File Inclusion
| Reported Severity: low
```

Remediation

```
Ensure JavaScript source files are loaded from only trusted sources, and the sources
can't be controlled by end users of the application.
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.

Finding notes: User Agent Fuzzer

Description

```
Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as
a Search Engine Crawler). Compares the response statuscode and the hashcode of the
response body with the original response.
```

Evidence

```
Target: https://owasp-juice.shop | Finding: User Agent Fuzzer | Reported Severity:
informational
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. Refer to scanner documentation for specific remediation steps

References:

- https://owasp.org/wstg

Finding notes: Retrieved from Cache

Description

```
The content was retrieved from a shared cache. If the response data is sensitive,
personal or user-specific, this may result in sensitive information being leaked. In some
cases, this may even result in a user gaining complete control of the session of another
user, depending on the configuration of the caching components in use in their
environment. This is primarily an issue where caching servers such as "proxy" caches are
configured on the local network. This configuration is typically found in corporate or
educational environments, for instance.
```

Evidence

```
Target: https://owasp-juice.shop | Finding: Retrieved from Cache | Reported Severity:
informational
```

Remediation

```
Validate that the response does not contain sensitive, personal or user-specific
information. If it does, consider the use of the following HTTP response headers, to
limit, or prevent the content being stored and retrieved from the cache by another
user:Cache-Control: no-cache, no-store, must-revalidate, privatePragma: no-cacheExpires:
```

```
0This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not
store the response, and to not retrieve the response (without validation) from the cache,
in response to a similar request.
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:Cache-Control: no-cache, no-store, must-revalidate, privatePragma: no-cacheExpires: 0This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching server...

References:

- https://datatracker.ietf.org/doc/html/rfc7234
- https://datatracker.ietf.org/doc/html/rfc7231
- https://www.rfc-editor.org/rfc/rfc9110.html

Finding notes: Re-examine Cache-control Directives

Description

```
The cache-control header has not been set properly or is missing, allowing the browser
and proxies to cache content. For static assets like css, js, or image files this might
```

```
be intended, however, the resources should be reviewed to ensure that no sensitive
content will be cached.
```

Evidence

```
Target: https://owasp-juice.shop | Finding: Re-examine Cache-control Directives |
Reported Severity: informational
```

Remediation

```
For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store,
must-revalidate". If an asset should be cached consider setting the directives "public,
max-age, immutable".
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".

References:

- https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control
- https://grayduck.mn/2021/09/13/cache-control-recommendations/

Finding notes: Modern Web Application

Description

```
The application appears to be a modern web application. If you need to explore it
automatically then the Ajax Spider may well be more effective than the standard one.
```

Evidence

```
Target: https://owasp-juice.shop | Finding: Modern Web Application | Reported Severity:
informational
```

Remediation

```
This is an informational alert and so no changes are required.
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. This is an informational alert and so no changes are required.

Asset: VAPTOR001A0003

Asset fingerprint

Field	Value
MAC Address	N/A
IP	137.74.187.100
Hostname	hackthissite.org
OS fingerprint	N/A

Open ports

Proto	Port	Service	Risk
tcp	80	http	HIGH
tcp	443	https	MEDIUM

High-risk port notes (VaptorAI / Intel DB)

Port exposure notes (VaptorAI): tcp/80 http [HIGH]

Narrative

```
# Port Exposure: tcp/80

## Summary
```

```
An Internet-accessible service was detected on tcp/80. Exposed management and remote-
access ports are frequently targeted for credential attacks and exploitation.

## Why this matters (Risk)
- Increases attack surface and brute-force exposure
- May permit remote code execution if vulnerable and unpatched
- Often enables lateral movement once credentials are obtained

## Recommended actions (Remediation)
- Restrict access (VPN/jump host/allowlist)
- Enforce MFA and strong authentication policies
- Patch the exposed service and disable legacy/insecure options

## Evidence
- Observed open: tcp/80
```

Port exposure notes: tcp/80 http [HIGH]

Why this matters Unencrypted web traffic; web application vulnerabilities, MitM attacks

Common attacksSQL Injection, XSS, CSRF, Directory Traversal, Man-in-the-Middle, Session Hijacking

Notable CVEsCVE-2021-44228, CVE-2017-5638, CVE-2014-0160

Recommended action Redirect all traffic to HTTPS (port 443). Disable HTTP or use only for redirect. Implement HSTS headers.

Watchdog mini-recap

- **Exposed:** 2 open port(s), 1 high-risk service(s).
  Top: tcp/80 http [HIGH]; tcp/443 https [MEDIUM]
- **Vulnerable:** 0 finding(s) (Critical 0, High 0, Medium 0).
- **Evidence:** 0/0 finding(s) include evidence snippets.
- **Remediation:** 0/0 finding(s) include remediation guidance.

Vulnerabilities

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

None found.

Asset: VAPTOR001A0004

Asset fingerprint

Field	Value
MAC Address	N/A

Field	Value
IP	31.3.96.40
Hostname	web.mmebvba.com
OS fingerprint	N/A

Open ports

Proto	Port	Service	Risk
tcp	22	—	HIGH
tcp	80	—	HIGH
tcp	443	—	MEDIUM

High-risk port notes (VaptorAI / Intel DB)

Port exposure notes (VaptorAI): tcp/22 — [HIGH]

Narrative

```
# Port Exposure: tcp/22

## Summary
An Internet-accessible service was detected on tcp/22. Exposed management and remote-
```

```
access ports are frequently targeted for credential attacks and exploitation.

## Why this matters (Risk)
- Increases attack surface and brute-force exposure
- May permit remote code execution if vulnerable and unpatched
- Often enables lateral movement once credentials are obtained

## Recommended actions (Remediation)
- Restrict access (VPN/jump host/allowlist)
- Enforce MFA and strong authentication policies
- Patch the exposed service and disable legacy/insecure options

## Evidence
- Observed open: tcp/22
```

Port exposure notes: tcp/22 — [HIGH]

Why this matters Remote shell access; brute-force, key reuse, weak credentials

Common attacks Brute Force, Credential Stuffing, Private Key Theft, Man-in-the-Middle

Notable CVEsCVE-2016-20012, CVE-2018-15473, CVE-2021-28041

Recommended action Implement key-based authentication only. Disable password authentication. Use fail2ban. Restrict access by IP. Enable 2FA.

Port exposure notes (VaptorAI): tcp/80 — [HIGH]

Narrative

```
# Port Exposure: tcp/80

## Summary
An Internet-accessible service was detected on tcp/80. Exposed management and remote-
access ports are frequently targeted for credential attacks and exploitation.

## Why this matters (Risk)
- Increases attack surface and brute-force exposure
- May permit remote code execution if vulnerable and unpatched
- Often enables lateral movement once credentials are obtained

## Recommended actions (Remediation)
- Restrict access (VPN/jump host/allowlist)
- Enforce MFA and strong authentication policies
- Patch the exposed service and disable legacy/insecure options

## Evidence
- Observed open: tcp/80
```

Port exposure notes: tcp/80 — [HIGH]

Why this matters Unencrypted web traffic; web application vulnerabilities, MitM attacks

Common attacksSQL Injection, XSS, CSRF, Directory Traversal, Man-in-the-Middle, Session Hijacking

Notable CVEsCVE-2021-44228, CVE-2017-5638, CVE-2014-0160

Recommended action Redirect all traffic to HTTPS (port 443). Disable HTTP or use only for redirect. Implement HSTS headers.

Watchdog mini-recap

- **Exposed:** 3 open port(s), 2 high-risk service(s).
  Top: tcp/22 — [HIGH]; tcp/80 — [HIGH]; tcp/443 — [MEDIUM]
- **Vulnerable:** 6 finding(s) (Critical 0, High 0, Medium 4).
- **Evidence:** 6/6 finding(s) include evidence snippets.
- **Remediation:** 5/6 finding(s) include remediation guidance.
  Suggested: Provide a valid integrity attribute to the tag.; Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.If you expect the ...

Vulnerabilities (6)

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

Severity	Title	CVE	CVSS
MEDIUM	Sub Resource Integrity Attribute Missing	—	5.0
MEDIUM	Missing Anti-clickjacking Header	—	5.0
MEDIUM	HTTP Only Site	—	5.0
MEDIUM	Content Security Policy (CSP) Header Not Set	—	5.0
LOW	X-Content-Type-Options Header Missing	—	2.5
INFO	User Agent Fuzzer	—	0.0

Finding notes: Sub Resource Integrity Attribute Missing

Description

```
The integrity attribute is missing on a script or link tag served by an external server.
The integrity tag prevents an attacker who have gained access to this server from
injecting a malicious content.
```

Evidence

```
Target: http://www.itsecgames.com | Finding: Sub Resource Integrity Attribute Missing |
Reported Severity: medium
```

Remediation

```
Provide a valid integrity attribute to the tag.
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. Provide a valid integrity attribute to the tag.

References:

- https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity

Finding notes: Missing Anti-clickjacking Header

Description

```
The response does not protect against 'ClickJacking' attacks. It should include either
Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
```

Evidence

```
Target: http://www.itsecgames.com/bugs.htm | Finding: Missing Anti-clickjacking Header |
Reported Severity: medium
```

Remediation

```
Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers.
Ensure one of them is set on all web pages returned by your site/app.If you expect the
```

```
page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll
want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should
use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors"
directive.
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security...

References:

- https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Finding notes: HTTP Only Site

Description

```
The site is only served under HTTP and not HTTPS.
```

Evidence

```
Target: http://www.itsecgames.com | Finding: HTTP Only Site | Reported Severity: medium
```

Remediation

```
Configure your web or application server to use SSL (https).
```

Remediation (detailed)

Effort: Variable
Business impact: Depends on vulnerability context

1. Configure your web or application server to use SSL (https).

References:

- https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html
- https://letsencrypt.org/

Finding notes: Content Security Policy (CSP) Header Not Set

Description

```
Content Security Policy (CSP) is an added layer of security that helps to detect and
mitigate certain types of attacks, including Cross Site Scripting (XSS) and data
injection attacks. These attacks are used for everything from data theft to site
defacement or distribution of malware. CSP provides a set of standard HTTP headers that
allow website owners to declare approved sources of content that browsers should be
```

```
allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts,
images and embeddable objects such as Java applets, ActiveX, audio and video files.
```

Evidence

```
Target: http://www.itsecgames.com | Finding: Content Security Policy (CSP) Header Not Set
| Reported Severity: medium
```

Remediation

```
Ensure that your web server, application server, load balancer, etc. is configured to set
the Content-Security-Policy header.
```

Remediation (detailed)

Effort: 30 minutes - 1 hour
Business impact: MEDIUM - Reduces attack surface and provides defense-in-depth

1. Add Content-Security-Policy header
2. Add X-Frame-Options header to prevent clickjacking
3. Add X-Content-Type-Options: nosniff
4. Add Strict-Transport-Security (HSTS) for HTTPS sites
5. Add X-XSS-Protection for legacy browser support
6. Remove Server header to reduce information disclosure

Verification:

- Use curl to check headers: curl -I https://example.com
- Use online tools like securityheaders.com

- Check with browser developer tools (Network tab)
- Use automated scanners to verify implementation

References:

- https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
- https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
- https://www.w3.org/TR/CSP/
- https://w3c.github.io/webappsec-csp/
- https://web.dev/articles/csp
- https://caniuse.com/#feat=contentsecuritypolicy
- https://content-security-policy.com/
- https://owasp.org/www-project-secure-headers/
- https://securityheaders.com/
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers

Finding notes: X-Content-Type-Options Header Missing

Description

```
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This
allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the
response body, potentially causing the response body to be interpreted and displayed as a
content type other than the declared content type. Current (early 2014) and legacy
versions of Firefox will use the declared content type (if one is set), rather than
performing MIME-sniffing.
```

Evidence

```
Target: http://www.itsecgames.com | Finding: X-Content-Type-Options Header Missing |
Reported Severity: low
```

Remediation

```
Ensure that the application/web server sets the Content-Type header appropriately, and
that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.If
possible, ensure that the end user uses a standards-compliant and modern web browser that
does not perform MIME-sniffing at all, or that can be directed by the web application/web
server to not perform MIME-sniffing.
```

Remediation (detailed)

Effort: 30 minutes - 1 hour
Business impact: MEDIUM - Reduces attack surface and provides defense-in-depth

1. Add Content-Security-Policy header
2. Add X-Frame-Options header to prevent clickjacking
3. Add X-Content-Type-Options: nosniff
4. Add Strict-Transport-Security (HSTS) for HTTPS sites
5. Add X-XSS-Protection for legacy browser support
6. Remove Server header to reduce information disclosure

Verification:

- Use curl to check headers: curl -I https://example.com
- Use online tools like securityheaders.com

- Check with browser developer tools (Network tab)
- Use automated scanners to verify implementation

References:

- https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85
- https://owasp.org/www-community/Security_Headers
- https://owasp.org/www-project-secure-headers/
- https://securityheaders.com/
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers

Finding notes: User Agent Fuzzer

Description

```
Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as
a Search Engine Crawler). Compares the response statuscode and the hashcode of the
response body with the original response.
```

Evidence

```
Target: http://www.itsecgames.com/downloads | Finding: User Agent Fuzzer | Reported
Severity: informational
```

Remediation (detailed)

Effort: Variable

Business impact: Depends on vulnerability context

1. Refer to scanner documentation for specific remediation steps

References:

- https://owasp.org/wstg

Asset: VAPTOR001A0005

Asset fingerprint

Field	Value
MAC Address	N/A
IP	44.228.249.3
Hostname	ec2-44-228-249-3.us-west-2.compute.amazonaws.com
OS fingerprint	Linux 4.15

Open ports

Proto	Port	Service	Risk
tcp	80	http	HIGH

High-risk port notes (VaptorAI / Intel DB)

Port exposure notes (VaptorAI): tcp/80 http [HIGH]

Narrative

```
# Port Exposure: tcp/80

## Summary
An Internet-accessible service was detected on tcp/80. Exposed management and remote-
access ports are frequently targeted for credential attacks and exploitation.

## Why this matters (Risk)
- Increases attack surface and brute-force exposure
- May permit remote code execution if vulnerable and unpatched
- Often enables lateral movement once credentials are obtained

## Recommended actions (Remediation)
- Restrict access (VPN/jump host/allowlist)
- Enforce MFA and strong authentication policies
- Patch the exposed service and disable legacy/insecure options

## Evidence
- Observed open: tcp/80
```

Port exposure notes: tcp/80 http [HIGH]

Why this matters Unencrypted web traffic; web application vulnerabilities, MitM attacks

Common attacksSQL Injection, XSS, CSRF, Directory Traversal, Man-in-the-Middle, Session Hijacking

Notable CVEsCVE-2021-44228, CVE-2017-5638, CVE-2014-0160

Recommended action Redirect all traffic to HTTPS (port 443). Disable HTTP or use only for redirect. Implement HSTS headers.

Watchdog mini-recap

- **Exposed:** 1 open port(s), 1 high-risk service(s).
  Top: tcp/80 http [HIGH]
- **Vulnerable:** 0 finding(s) (Critical 0, High 0, Medium 0).
- **Evidence:** 0/0 finding(s) include evidence snippets.
- **Remediation:** 0/0 finding(s) include remediation guidance.

Vulnerabilities

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

None found.

Asset: VAPTOR001A0006

Asset fingerprint

Field	Value
MAC Address	N/A
IP	44.238.29.244
Hostname	ec2-44-238-29-244.us-west-2.compute.amazonaws.com
OS fingerprint	Microsoft Windows Server 2012 or Windows Server 2012 R2

Open ports

Proto	Port	Service	Risk
tcp	80	http	HIGH

High-risk port notes (VaptorAI / Intel DB)

Port exposure notes (VaptorAI): tcp/80 http [HIGH]

Narrative

```
# Port Exposure: tcp/80
```

```
## Summary
An Internet-accessible service was detected on tcp/80. Exposed management and remote-
access ports are frequently targeted for credential attacks and exploitation.

## Why this matters (Risk)
- Increases attack surface and brute-force exposure
- May permit remote code execution if vulnerable and unpatched
- Often enables lateral movement once credentials are obtained

## Recommended actions (Remediation)
- Restrict access (VPN/jump host/allowlist)
- Enforce MFA and strong authentication policies
- Patch the exposed service and disable legacy/insecure options

## Evidence
- Observed open: tcp/80
```

Port exposure notes: tcp/80 http [HIGH]

Why this matters Unencrypted web traffic; web application vulnerabilities, MitM attacks

Common attacksSQL Injection, XSS, CSRF, Directory Traversal, Man-in-the-Middle, Session Hijacking

Notable CVEsCVE-2021-44228, CVE-2017-5638, CVE-2014-0160

Recommended action Redirect all traffic to HTTPS (port 443). Disable HTTP or use only for redirect. Implement HSTS headers.

Watchdog mini-recap

- **Exposed:** 1 open port(s), 1 high-risk service(s).
  Top: tcp/80 http [HIGH]
- **Vulnerable:** 0 finding(s) (Critical 0, High 0, Medium 0).
- **Evidence:** 0/0 finding(s) include evidence snippets.
- **Remediation:** 0/0 finding(s) include remediation guidance.

Vulnerabilities

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

None found.

Asset: VAPTOR001A0007

Asset fingerprint

Field	Value
MAC Address	B8:27:EB:74:F2:6C

Field	Value
IP	10.0.0.132
Hostname	N/A
OS fingerprint	Linux 4.15 - 5.19

Open ports

Proto	Port	Service	Risk
tcp	22	ssh	HIGH

High-risk port notes (VaptorAI / Intel DB)

Port exposure notes (VaptorAI): tcp/22 ssh [HIGH]

Narrative

```
# Port Exposure: tcp/22

## Summary
An Internet-accessible service was detected on tcp/22. Exposed management and remote-
access ports are frequently targeted for credential attacks and exploitation.

## Why this matters (Risk)
```

```
- Increases attack surface and brute-force exposure
- May permit remote code execution if vulnerable and unpatched
- Often enables lateral movement once credentials are obtained

## Recommended actions (Remediation)
- Restrict access (VPN/jump host/allowlist)
- Enforce MFA and strong authentication policies
- Patch the exposed service and disable legacy/insecure options

## Evidence
- Observed open: tcp/22
```

Port exposure notes: tcp/22 ssh [HIGH]

Why this matters Remote shell access; brute-force, key reuse, weak credentials

Common attacks Brute Force, Credential Stuffing, Private Key Theft, Man-in-the-Middle

Notable CVEsCVE-2016-20012, CVE-2018-15473, CVE-2021-28041

Recommended action Implement key-based authentication only. Disable password authentication. Use fail2ban. Restrict access by IP. Enable 2FA.

Watchdog mini-recap

- **Exposed:** 1 open port(s), 1 high-risk service(s).
  Top: tcp/22 ssh [HIGH]
- **Vulnerable:** 0 finding(s) (Critical 0, High 0, Medium 0).
- **Evidence:** 0/0 finding(s) include evidence snippets.
- **Remediation:** 0/0 finding(s) include remediation guidance.

Vulnerabilities

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

None found.

Asset: VAPTOR001A0008

Asset fingerprint

Field	Value
MAC Address	38:53:9C:B8:D1:98
IP	10.0.0.105
Hostname	N/A

Field	Value
OS fingerprint	Apple macOS 11 (Big Sur) - 13 (Ventura) or iOS 16 (Darwin 20.6.0 - 22.4.0)

Open ports

Proto	Port	Service	Risk
tcp	49152	—	—
tcp	62078	iphone-sync	—

Watchdog mini-recap

- **Exposed:** 2 open port(s), 0 high-risk service(s).
  Top: tcp/49152 —; tcp/62078 iphone-sync
- **Vulnerable:** 0 finding(s) (Critical 0, High 0, Medium 0).
- **Evidence:** 0/0 finding(s) include evidence snippets.
- **Remediation:** 0/0 finding(s) include remediation guidance.

Vulnerabilities

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

None found.

Asset: VAPTOR001A0009

Asset fingerprint

Field	Value
MAC Address	74:40:BB:72:FB:C5
IP	10.0.0.104
Hostname	N/A
OS fingerprint	Microsoft Windows 11 21H2

Open ports

Proto	Port	Service	Risk
tcp	6881	bittorrent-tracker	—

Watchdog mini-recap

- **Exposed:** 1 open port(s), 0 high-risk service(s).
  Top: tcp/6881 bittorrent-tracker

- **Vulnerable:** 0 finding(s) (Critical 0, High 0, Medium 0).
- **Evidence:** 0/0 finding(s) include evidence snippets.
- **Remediation:** 0/0 finding(s) include remediation guidance.

Vulnerabilities

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

None found.

Asset: VAPTOR001A0010

Asset fingerprint

Field	Value
MAC Address	42:27:0A:23:DF:92
IP	10.0.0.112
Hostname	N/A
OS fingerprint	N/A

Open ports

None recorded.

Watchdog mini-recap

- **Exposed:** 0 open port(s), 0 high-risk service(s).
- **Vulnerable:** 0 finding(s) (Critical 0, High 0, Medium 0).
- **Evidence:** 0/0 finding(s) include evidence snippets.
- **Remediation:** 0/0 finding(s) include remediation guidance.

Vulnerabilities

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

None found.

Asset: VAPTOR001A0011

Asset fingerprint

Field	Value
MAC Address	3C:0A:F3:3C:C1:A7
IP	10.0.0.110
Hostname	N/A

Field	Value
OS fingerprint	N/A

Open ports

None recorded.

Watchdog mini-recap

- **Exposed:** 0 open port(s), 0 high-risk service(s).
- **Vulnerable:** 0 finding(s) (Critical 0, High 0, Medium 0).
- **Evidence:** 0/0 finding(s) include evidence snippets.
- **Remediation:** 0/0 finding(s) include remediation guidance.

Vulnerabilities

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

None found.

Asset: VAPTOR001A0012

Asset fingerprint

Field	Value
MAC Address	70:F8:2B:1B:A3:68
IP	10.0.0.254
Hostname	www.adsl.vf
OS fingerprint	Linux 2.6.32 - 3.13

Open ports

Proto	Port	Service	Risk
tcp	53	domain	MEDIUM
tcp	80	http	HIGH
tcp	443	https	MEDIUM
tcp	1990	stun-p1	—

High-risk port notes (VaptorAI / Intel DB)

Port exposure notes (VaptorAI): tcp/80 http [HIGH]

Narrative

```
# Port Exposure: tcp/80

## Summary
An Internet-accessible service was detected on tcp/80. Exposed management and remote-
access ports are frequently targeted for credential attacks and exploitation.

## Why this matters (Risk)
- Increases attack surface and brute-force exposure
- May permit remote code execution if vulnerable and unpatched
- Often enables lateral movement once credentials are obtained

## Recommended actions (Remediation)
- Restrict access (VPN/jump host/allowlist)
- Enforce MFA and strong authentication policies
- Patch the exposed service and disable legacy/insecure options

## Evidence
- Observed open: tcp/80
```

Port exposure notes: tcp/80 http [HIGH]

Why this matters Unencrypted web traffic; web application vulnerabilities, MitM attacks

Common attacksSQL Injection, XSS, CSRF, Directory Traversal, Man-in-the-Middle, Session Hijacking

Notable CVEsCVE-2021-44228, CVE-2017-5638, CVE-2014-0160

Recommended action Redirect all traffic to HTTPS (port 443). Disable HTTP or use only for redirect. Implement HSTS headers.

Watchdog mini-recap

- **Exposed:** 4 open port(s), 1 high-risk service(s).
  Top: tcp/53 domain [MEDIUM]; tcp/80 http [HIGH]; tcp/443 https [MEDIUM]
- **Vulnerable:** 0 finding(s) (Critical 0, High 0, Medium 0).
- **Evidence:** 0/0 finding(s) include evidence snippets.
- **Remediation:** 0/0 finding(s) include remediation guidance.

Vulnerabilities

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

None found.

Asset: VAPTOR001A0013

Asset fingerprint

Field	Value
MAC Address	00:0c:29:70:f3:3f
IP	10.0.0.134
Hostname	N/A
OS fingerprint	N/A

Open ports

None recorded.

Watchdog mini-recap

- **Exposed:** 0 open port(s), 0 high-risk service(s).
- **Vulnerable:** 0 finding(s) (Critical 0, High 0, Medium 0).
- **Evidence:** 0/0 finding(s) include evidence snippets.
- **Remediation:** 0/0 finding(s) include remediation guidance.

Vulnerabilities

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

None found.

Asset: VAPTOR001A0014

Asset fingerprint

Field	Value
MAC Address	04:CB:01:4C:1B:1C
IP	10.0.0.124
Hostname	N/A
OS fingerprint	N/A

Open ports

None recorded.

Watchdog mini-recap

- **Exposed:** 0 open port(s), 0 high-risk service(s).
- **Vulnerable:** 0 finding(s) (Critical 0, High 0, Medium 0).
- **Evidence:** 0/0 finding(s) include evidence snippets.

- **Remediation:** 0/0 finding(s) include remediation guidance.

Vulnerabilities

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

None found.

Asset: VAPTOR001A0015

Asset fingerprint

Field	Value
MAC Address	16:41:0F:EC:FD:25
IP	10.0.0.133
Hostname	N/A
OS fingerprint	N/A

Open ports

None recorded.

Watchdog mini-recap

- **Exposed:** 0 open port(s), 0 high-risk service(s).
- **Vulnerable:** 0 finding(s) (Critical 0, High 0, Medium 0).
- **Evidence:** 0/0 finding(s) include evidence snippets.
- **Remediation:** 0/0 finding(s) include remediation guidance.

Vulnerabilities

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

None found.

Asset: VAPTOR001A0016

Asset fingerprint

Field	Value
MAC Address	F4:63:1F:59:71:1C
IP	10.0.0.106
Hostname	N/A
OS fingerprint	Citrix Access Gateway VPN gateway

Open ports

None recorded.

Watchdog mini-recap

- **Exposed:** 0 open port(s), 0 high-risk service(s).
- **Vulnerable:** 0 finding(s) (Critical 0, High 0, Medium 0).
- **Evidence:** 0/0 finding(s) include evidence snippets.
- **Remediation:** 0/0 finding(s) include remediation guidance.

Vulnerabilities

CVE/CVSS are shown when available; CVSS may be estimated from severity when not provided by the source.

None found.

3b) Audit (AI) - Log Analysis

AI-assisted analysis of uploaded security logs for this scan. Reports list audit artifacts only (not raw log contents) to reduce sensitive-data exposure.

Analysis Summary

Analysis completed: 2026-03-11 15:36:10 UTC

Files processed: 30

Vulnerabilities found: 3

Threats detected: 4

Recommendations: 4

Analyzed 25 scan-folder artifact files. Found 66 vulnerabilities, 89 threats, and 70 recommendations.

Security Vulnerabilities Identified (3)

Title	Severity	Description	Source Artifact
CVE reference found	HIGH	CVE reference found	wapiti_results.json
Weak configuration/credential	MEDIUM	Weak configuration/credential	wapiti_results.json
Vulnerability mention	MEDIUM	Vulnerability mention	wapiti_results.json

Security Threats Detected (4)

Threat	Severity	Category	Source Artifact
Exploit attempt signatures	MEDIUM	exploit	scanner_execution.json, wapiti_results.json

Unauthorized access attempts	MEDIUM	unauthorized	wapiti_results.json
Potential attack indicators	MEDIUM	attack	wapiti_results.json
Injection attempt patterns	MEDIUM	injection	wapiti_results.json

Security Recommendations (4)

Priority	Category	Recommended Action	Source File
HIGH	Security	Investigate threat indicators immediately	—
HIGH	Patching	Apply patches and security updates for identified vulnerabilities	—
MEDIUM	Monitoring	Review anomalies for potential system or security issues	—
LOW	Monitoring	Continue regular monitoring and log review	—

4) Compliance Evaluation & Score

This section is informational and helps triage findings against control frameworks. It is not a formal compliance audit. Controls are marked **Non-Compliant** when mapped findings exist for this scan; controls only become **Compliant** when audit evidence (vaptaudit) explicitly marks them as PASS.

Metric	Value
Percent compliant	4% (Low)
Control coverage	7/74 (9%)
Vulnerability-to-control mapping	0/51 (0%)
Auto mapping (bootstrap)	No

Compliance Summary by Framework

Framework	Compliant	Non-Compliant	Unmapped
HIPAA	0/57 (0%)	4	53
ISO-27001	0/5 (0%)	1	4
NIST-CSF	0/7 (0%)	1	6
PCI-DSS	0/5 (0%)	1	4

Compliance Controls (Addendum)

Status legend: **Compliant**=Informational: vaptaudit provided PASS evidence for this control for this scan.; **Non-Compliant**=Informational: a mapped finding impacts this control for this scan (or vaptaudit marked FAIL).; **Unmapped**=Informational: no mapped findings for this control and no vaptaudit PASS evidence.

Framework	Control Title	Affected AssetUID	Status
HIPAA	Security Management Process	VAPTOR001A0001, VAPTOR001A0002, VAPTOR001A0004	Non-Compliant
HIPAA	Security Management Process - Risk Analysis	VAPTOR001A0001, VAPTOR001A0002, VAPTOR001A0004	Non-Compliant
HIPAA	Security Management Process - Risk Management	—	Unmapped
HIPAA	Security Management Process - Sanction Policy	—	Unmapped
HIPAA	Security Management Process - Information System Activity Review	—	Unmapped
HIPAA	Assigned Security Responsibility	—	Unmapped
HIPAA	Workforce Security	—	Unmapped
HIPAA	Workforce Security - Authorization and Supervision	—	Unmapped
HIPAA	Workforce Security - Clearance Procedure	—	Unmapped

Framework	Control Title	Affected AssetUID	Status
HIPAA	Workforce Security - Termination Procedures	—	Unmapped
HIPAA	Information Access Management	—	Unmapped
HIPAA	Information Access Management - Access Authorization	—	Unmapped
HIPAA	Information Access Management - Access Establishment and Modification	—	Unmapped
HIPAA	Security Awareness and Training	—	Unmapped
HIPAA	Security Awareness and Training	—	Unmapped
HIPAA	Security Awareness and Training - Security Reminders	—	Unmapped
HIPAA	Security Awareness and Training - Protection from Malicious Software	—	Unmapped
HIPAA	Security Awareness and Training - Log-in Monitoring	—	Unmapped
HIPAA	Security Awareness and Training - Password Management	—	Unmapped

Framework	Control Title	Affected AssetUID	Status
HIPAA	Security Incident Procedures	—	Unmapped
HIPAA	Security Incident Procedures - Response and Reporting	—	Unmapped
HIPAA	Contingency Plan	—	Unmapped
HIPAA	Contingency Plan - Data Backup	—	Unmapped
HIPAA	Contingency Plan - Disaster Recovery	—	Unmapped
HIPAA	Contingency Plan - Emergency Mode Operation	—	Unmapped
HIPAA	Contingency Plan - Testing and Revision	—	Unmapped
HIPAA	Evaluation	—	Unmapped
HIPAA	Business Associate Contracts	—	Unmapped
HIPAA	Facility Access Controls	—	Unmapped
HIPAA	Facility Access Controls - Contingency Operations	—	Unmapped
HIPAA		—	Unmapped

Framework	Control Title	Affected AssetUID	Status
	Facility Access Controls - Facility Security Plan		
HIPAA	Facility Access Controls - Access Control and Validation	—	Unmapped
HIPAA	Facility Access Controls - Maintenance Records	—	Unmapped
HIPAA	Workstation Use	VAPTOR001A0001	Non-Compliant
HIPAA	Workstation Security	—	Unmapped
HIPAA	Device and Media Controls - Disposal	—	Unmapped
HIPAA	Device and Media Controls - Media Re-use	—	Unmapped
HIPAA	Device and Media Controls - Accountability	—	Unmapped
HIPAA	Device and Media Controls - Data Backup and Storage	—	Unmapped
HIPAA	Access Control	—	Unmapped
HIPAA	Access Control - Unique User Identification	—	Unmapped

Framework	Control Title	Affected AssetUID	Status
HIPAA	Access Control - Emergency Access Procedure	—	Unmapped
HIPAA	Access Control - Automatic Logoff	—	Unmapped
HIPAA	Access Control - Encryption and Decryption	—	Unmapped
HIPAA	Audit Controls	—	Unmapped
HIPAA	Integrity	—	Unmapped
HIPAA	Integrity - Mechanism to Authenticate ePHI	—	Unmapped
HIPAA	Person or Entity Authentication	—	Unmapped
HIPAA	Transmission Security	—	Unmapped
HIPAA	Transmission Security - Integrity Controls	VAPTOR001A0001	Non-Compliant
HIPAA	Transmission Security - Encryption	—	Unmapped
HIPAA	Business Associate Contracts - Written Contract	—	Unmapped
HIPAA	Requirements for Group Health Plans	—	Unmapped

Framework	Control Title	Affected AssetUID	Status
HIPAA	Policies and Procedures	—	Unmapped
HIPAA	Documentation - Time Limit	—	Unmapped
HIPAA	Documentation - Availability	—	Unmapped
HIPAA	Documentation - Updates	—	Unmapped
ISO-27001	Policies for information security	VAPTOR001A0001, VAPTOR001A0002	Non-Compliant
ISO-27001	Screening	—	Unmapped
ISO-27001	Physical security perimeters	—	Unmapped
ISO-27001	User endpoint devices	—	Unmapped
ISO-27001	Privileged access rights	—	Unmapped
NIST-CSF	Networks are monitored	—	Unmapped
NIST-CSF	Asset inventories are maintained	—	Unmapped
NIST-CSF	Software platforms are inventoried	VAPTOR001A0001	Non-Compliant
NIST-CSF	Identities are managed	—	Unmapped

Framework	Control Title	Affected AssetUID	Status
NIST-CSF	Remote access is managed	—	Unmapped
NIST-CSF	Recovery plan is executed	—	Unmapped
NIST-CSF	Response plan is executed	—	Unmapped
PCI-DSS	Firewall configuration standards	—	Unmapped
PCI-DSS	Change default passwords	—	Unmapped
PCI-DSS	CHD retention policy	—	Unmapped
PCI-DSS	Strong cryptography for CHD transmission	—	Unmapped
PCI-DSS	Secure development processes	VAPTOR001A0001	Non-Compliant

Vulnerability → Control Trace (This Scan)

This links findings to impacted controls so users can see why a control is flagged as Non-Compliant.

AssetUID	Severity	Finding	Impacted Controls
VAPTOR001A0001	INFORMATIONAL	User Agent Fuzzer	HIPAA: Security Management Process

AssetUID	Severity	Finding	Impacted Controls
VAPTOR001A0001	INFORMATIONAL	Information Disclosure - Sensitive Information in URL	HIPAA: Security Management Process - Risk Analysis
VAPTOR001A0001	INFORMATIONAL	Cookie Poisoning	HIPAA: Security Management Process
VAPTOR001A0001	LOW	Timestamp Disclosure - Unix	HIPAA: Security Management Process
VAPTOR001A0001	LOW	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	HIPAA: Security Management Process - Risk Analysis
VAPTOR001A0001	LOW	Private IP Disclosure	HIPAA: Security Management Process
VAPTOR001A0001	LOW	Information Disclosure - Debug Error Messages	HIPAA: Security Management Process - Risk Analysis
VAPTOR001A0001	LOW	In Page Banner Information Leak	HIPAA: Security Management Process - Risk Analysis
VAPTOR001A0001	MEDIUM	CSP: style-src unsafe-inline	HIPAA: Security Management Process
VAPTOR001A0001	MEDIUM	CSP: Wildcard Directive	

AssetUID	Severity	Finding	Impacted Controls
			HIPAA: Security Management Process
VAPTOR001A0001	MEDIUM	CSP: Failure to Define Directive with No Fallback	ISO-27001: Policies for information security
VAPTOR001A0001	MEDIUM	Application Error Disclosure	NIST-CSF: Software platforms are inventoried
VAPTOR001A0001	INFORMATIONAL	User Controllable HTML Element Attribute (Potential XSS)	HIPAA: Workstation Use
VAPTOR001A0001	INFORMATIONAL	Information Disclosure - Suspicious Comments	HIPAA: Security Management Process - Risk Analysis
VAPTOR001A0001	LOW	Server Leaks Version Information via "Server" HTTP Response Header Field	HIPAA: Security Management Process - Risk Analysis
VAPTOR001A0001	LOW	Secure Pages Include Mixed Content	PCI-DSS: Secure development processes
VAPTOR001A0001	LOW	Cross-Domain JavaScript Source File Inclusion	HIPAA: Security Management Process
VAPTOR001A0001	LOW	Cookie No HttpOnly Flag	HIPAA: Security Management Process

AssetUID	Severity	Finding	Impacted Controls
VAPTOR001A0001	MEDIUM	Vulnerable JS Library	HIPAA: Security Management Process
VAPTOR001A0001	MEDIUM	Sub Resource Integrity Attribute Missing	HIPAA: Security Management Process - Risk Analysis
VAPTOR001A0001	MEDIUM	Missing Anti-clickjacking Header	HIPAA: Security Management Process
VAPTOR001A0001	MEDIUM	Cross-Domain Misconfiguration	HIPAA: Security Management Process
VAPTOR001A0001	INFORMATIONAL	Session Management Response Identified	HIPAA: Security Management Process
VAPTOR001A0001	INFORMATIONAL	Re-examine Cache-control Directives	HIPAA: Security Management Process
VAPTOR001A0001	INFORMATIONAL	Modern Web Application	HIPAA: Security Management Process
VAPTOR001A0001	INFORMATIONAL	Authentication Request Identified	HIPAA: Security Management Process
VAPTOR001A0001	LOW	X-Content-Type-Options Header Missing	

AssetUID	Severity	Finding	Impacted Controls
			HIPAA: Security Management Process
VAPTOR001A0001	LOW	Strict-Transport-Security Header Not Set	HIPAA: Security Management Process
VAPTOR001A0001	LOW	Cookie without SameSite Attribute	HIPAA: Workstation Use
VAPTOR001A0001	LOW	Cookie Without Secure Flag	HIPAA: Transmission Security - Integrity Controls
VAPTOR001A0001	MEDIUM	Content Security Policy (CSP) Header Not Set	HIPAA: Security Management Process
VAPTOR001A0001	MEDIUM	Absence of Anti-CSRF Tokens	HIPAA: Security Management Process
VAPTOR001A0004	INFORMATIONAL	User Agent Fuzzer	HIPAA: Security Management Process
VAPTOR001A0004	LOW	X-Content-Type-Options Header Missing	HIPAA: Security Management Process
VAPTOR001A0004	MEDIUM	Sub Resource Integrity Attribute Missing	HIPAA: Security Management Process - Risk Analysis

AssetUID	Severity	Finding	Impacted Controls
VAPTOR001A0004	MEDIUM	Missing Anti-clickjacking Header	HIPAA: Security Management Process
VAPTOR001A0004	MEDIUM	HTTP Only Site	HIPAA: Security Management Process
VAPTOR001A0004	MEDIUM	Content Security Policy (CSP) Header Not Set	HIPAA: Security Management Process
VAPTOR001A0002	INFORMATIONAL	User Agent Fuzzer	HIPAA: Security Management Process
VAPTOR001A0002	INFORMATIONAL	Retrieved from Cache	HIPAA: Security Management Process
VAPTOR001A0002	INFORMATIONAL	Re-examine Cache-control Directives	HIPAA: Security Management Process
VAPTOR001A0002	INFORMATIONAL	Modern Web Application	HIPAA: Security Management Process
VAPTOR001A0002	INFORMATIONAL	Information Disclosure - Suspicious Comments	HIPAA: Security Management Process - Risk Analysis
VAPTOR001A0002	LOW	Strict-Transport-Security Header Not Set	

AssetUID	Severity	Finding	Impacted Controls
			HIPAA: Security Management Process
VAPTOR001A0002	LOW	Cross-Domain JavaScript Source File Inclusion	HIPAA: Security Management Process
VAPTOR001A0002	MEDIUM	Sub Resource Integrity Attribute Missing	HIPAA: Security Management Process - Risk Analysis
VAPTOR001A0002	MEDIUM	Cross-Domain Misconfiguration	HIPAA: Security Management Process
VAPTOR001A0002	MEDIUM	CSP: style-src unsafe-inline	HIPAA: Security Management Process
VAPTOR001A0002	MEDIUM	CSP: script-src unsafe-inline	HIPAA: Security Management Process
VAPTOR001A0002	MEDIUM	CSP: script-src unsafe-eval	HIPAA: Security Management Process
VAPTOR001A0002	MEDIUM	CSP: Failure to Define Directive with No Fallback	ISO-27001: Policies for information security

5) Remediation & Compliance Roadmap

1. Restrict exposure of 10.0.0.132:22 (HIGH). Implement key-based authentication only. Disable password authentication. Use fail2ban. Restrict access by IP. Enable 2FA.
2. Restrict exposure of 10.0.0.254:80 (HIGH). Redirect all traffic to HTTPS (port 443). Disable HTTP or use only for redirect. Implement HSTS headers.
3. Restrict exposure of 137.74.187.100:80 (HIGH). Redirect all traffic to HTTPS (port 443). Disable HTTP or use only for redirect. Implement HSTS headers.
4. Harden authentication: enforce MFA where possible, disable default credentials, and add account lockout policies for remote services.
5. Compliance: ensure control mappings are configured (set `compliance.default_control_id`) and remediate items mapped to highest-priority controls first.

Appendix A — Scan Artifact Index

Complete inventory of scan artifacts generated during this assessment.

Artifact Path	Size (bytes)
artifacts/ai_ready_summary.json	28,161
artifacts/api_scan.json	884
artifacts/VAPTORDISCOVERY.txt	602

Artifact Path	Size (bytes)
artifacts/consolidated_vulnerabilities.json	150,204
artifacts/consolidated_vulnerabilities_penetration_test.json	1,939
artifacts/consolidated_vulnerabilities_vulnerability_assessment.json	150,189
artifacts/dast/dast_summary.json	658
artifacts/dast/nuclei_results.json	2,519
artifacts/dast/nuclei_targets.txt	720
artifacts/dast/wapiti_10_http_31.3.96.40_80/wapiti_results.json	42,206
artifacts/dast/wapiti_11_https_31.3.96.40_443/wapiti_results.json	42,207
artifacts/dast/wapiti_12_http_44.228.249.3_80/wapiti_results.json	42,208
artifacts/dast/wapiti_13_http_44.238.29.244_80/wapiti_results.json	42,209
artifacts/dast/wapiti_14_http_81.169.145.156_80/wapiti_results.json	42,210
artifacts/dast/wapiti_15_https_81.169.145.156_443/wapiti_results.json	42,211
artifacts/dast/wapiti_16_http_81.169.145.156_8080/wapiti_results.json	42,215
artifacts/dast/wapiti_18_https_137.74.187.101_443/wapiti_results.json	42,211

Artifact Path	Size (bytes)
artifacts/dast/wapiti_1_https_pentest-ground.com/wapiti_results.json	42,215
artifacts/dast/wapiti_20_https_137.74.187.103_443/wapiti_results.json	42,211
artifacts/dast/wapiti_22_https_137.74.187.102_443/wapiti_results.json	42,211
artifacts/dast/wapiti_23_http_10.0.0.254_80/wapiti_results.json	42,206
artifacts/dast/wapiti_24_https_10.0.0.254_443/wapiti_results.json	42,207
artifacts/dast/wapiti_26_https_137.74.187.104_443/wapiti_results.json	42,211
artifacts/dast/wapiti_2_https_owasp-juice.shop_/wapiti_results.json	42,213
artifacts/dast/wapiti_3_https_www.hackthissite.org_/wapiti_results.json	42,217
artifacts/dast/wapiti_4_http_www.itsecgames.com_/wapiti_results.json	42,214
artifacts/dast/wapiti_5_http_www.vulnweb.com_/wapiti_results.json	42,211
artifacts/dast/wapiti_6_http_testhtml5.vulnweb.com/wapiti_results.json	42,217
artifacts/dast/wapiti_7_http_testphp.vulnweb.com/wapiti_results.json	42,215
artifacts/dast/wapiti_8_http_testasp.vulnweb.com/wapiti_results.json	42,215
artifacts/dast/wapiti_9_http_testaspnet.vulnweb.com/wapiti_results.json	42,218

Artifact Path	Size (bytes)
artifacts/dast/wapiti_summary.json	6,447
artifacts/discovery/_nmap_chunks/VAPTORDISCOVERY-part-1.xml	126,770
artifacts/discovery/_nmap_chunks/VAPTORDISCOVERY-part-2.xml	164,518
artifacts/discovery/_nmap_chunks/VAPTORDISCOVERY-part-3.xml	100,720
artifacts/discovery/discovery.csv	945
artifacts/discovery/discovery.json	76,678
artifacts/discovery/discovery.yaml	2,045
artifacts/discovery/httpx_targets.txt	721
artifacts/discovery/httpx_web.jsonl	14,635
artifacts/discovery/VAPTORDISCOVERY.xml	357,459
artifacts/discovery/websites.json	9,198
artifacts/discovery.csv	945
artifacts/discovery.json	76,678
artifacts/enrichment/1990.json	1,901

Artifact Path	Size (bytes)
artifacts/enrichment/21.json	1,888
artifacts/enrichment/22.json	1,949
artifacts/enrichment/443.json	2,443
artifacts/enrichment/4445.json	1,935
artifacts/enrichment/49152.json	1,882
artifacts/enrichment/53.json	1,886
artifacts/enrichment/62078.json	1,903
artifacts/enrichment/6881.json	1,903
artifacts/enrichment/80.json	2,657
artifacts/enrichment/8080.json	1,909
artifacts/enrichment/builtwith.json	1,855
artifacts/enrichment/vuln_046bd80873e5.json	2,115
artifacts/enrichment/vuln_07e1dc8ebe12.json	2,151
artifacts/enrichment/vuln_0c90fd0f417e.json	2,154

Artifact Path	Size (bytes)
artifacts/enrichment/vuln_1b0cb68058b7.json	2,167
artifacts/enrichment/vuln_1bb136a33b85.json	2,138
artifacts/enrichment/vuln_20e2f0b68c46.json	2,221
artifacts/enrichment/vuln_212a43550c6b.json	2,169
artifacts/enrichment/vuln_2218aea5a2fd.json	2,239
artifacts/enrichment/vuln_30da74808b98.json	2,155
artifacts/enrichment/vuln_339c50ff076a.json	2,109
artifacts/enrichment/vuln_390ae64d9285.json	2,268
artifacts/enrichment/vuln_3927120d6e3f.json	2,175
artifacts/enrichment/vuln_3f2b931f5043.json	2,214
artifacts/enrichment/vuln_4731868892aa.json	2,226
artifacts/enrichment/vuln_626762e2bdc0.json	2,249
artifacts/enrichment/vuln_64e884f319b5.json	2,148
artifacts/enrichment/vuln_65513f796eca.json	2,282

Artifact Path	Size (bytes)
artifacts/enrichment/vuln_744643c88a42.json	2,214
artifacts/enrichment/vuln_786242826d8b.json	2,150
artifacts/enrichment/vuln_7b8b8ce898ee.json	2,219
artifacts/enrichment/vuln_7f7dc822c519.json	2,242
artifacts/enrichment/vuln_8c9fdc8d3bcc.json	2,265
artifacts/enrichment/vuln_94a3339e6509.json	2,163
artifacts/enrichment/vuln_9917e1b21079.json	2,204
artifacts/enrichment/vuln_9c5711131167.json	2,287
artifacts/enrichment/vuln_ab7aaa6d20a9.json	2,133
artifacts/enrichment/vuln_b215a728697a.json	2,157
artifacts/enrichment/vuln_b36ecfa8f5ba.json	2,166
artifacts/enrichment/vuln_b3c299a3d7a4.json	2,117
artifacts/enrichment/vuln_b4a981b5f9f6.json	2,286
artifacts/enrichment/vuln_b6c1410b4e6a.json	2,153

Artifact Path	Size (bytes)
artifacts/enrichment/vuln_b9bf54cb9a67.json	2,115
artifacts/enrichment/vuln_bc1c95a5b14b.json	2,181
artifacts/enrichment/vuln_bc95a54657ff.json	2,139
artifacts/enrichment/vuln_c17d5e3e452c.json	2,255
artifacts/enrichment/vuln_d0cfd339ccbb.json	2,169
artifacts/enrichment/vuln_d56574b60a09.json	2,166
artifacts/enrichment/vuln_db681037cedb.json	2,073
artifacts/enrichment/vuln_dccc429b9024.json	2,259
artifacts/enrichment/vuln_e2d1361b08b5.json	2,205
artifacts/enrichment/vuln_e2d17690ace2.json	2,132
artifacts/enrichment/vuln_e42ead0fd475.json	2,272
artifacts/enrichment/vuln_e99b138feab9.json	2,217
artifacts/enrichment/vuln_e9e5fee48798.json	2,420
artifacts/enrichment/vuln_eace7891c929.json	2,262

Artifact Path	Size (bytes)
artifacts/enrichment/vuln_f45577f225d5.json	2,172
artifacts/enrichment/vuln_f4ac24e3b3bc.json	2,139
artifacts/enrichment/vuln_f6b3440a207d.json	2,220
artifacts/enrichment/vuln_fb4b1537d54b.json	2,198
artifacts/enrichment/vuln_fd39bb169a01.json	2,115
artifacts/enrichment/vuln_fdc5fa62abd3.json	2,135
artifacts/enrichment/whois.json	9,653
artifacts/enrichment.json	2,562
artifacts/VAPTORMSF/auto_10_0_0_104.rc	143
artifacts/VAPTORMSF/auto_10_0_0_105.rc	150
artifacts/VAPTORMSF/auto_10_0_0_132.rc	225
artifacts/VAPTORMSF/auto_10_0_0_254.rc	475
artifacts/VAPTORMSF/auto_137_74_187_100.rc	409
artifacts/VAPTORMSF/auto_137_74_187_101.rc	409

Artifact Path	Size (bytes)
artifacts/VAPTORMSF/auto_137_74_187_102.rc	409
artifacts/VAPTORMSF/auto_137_74_187_103.rc	409
artifacts/VAPTORMSF/auto_137_74_187_104.rc	409
artifacts/VAPTORMSF/auto_178_79_134_182.rc	151
artifacts/VAPTORMSF/auto_31_3_96_40.rc	476
artifacts/VAPTORMSF/auto_44_228_249_3.rc	316
artifacts/VAPTORMSF/auto_44_238_29_244.rc	320
artifacts/VAPTORMSF/auto_81_169_145_156.rc	682
artifacts/VAPTORMSF/msf_10_0_0_104.txt	1,474
artifacts/VAPTORMSF/msf_10_0_0_105.txt	1,545
artifacts/VAPTORMSF/msf_10_0_0_132.txt	2,351
artifacts/VAPTORMSF/msf_10_0_0_254.txt	4,998
artifacts/VAPTORMSF/msf_137_74_187_100.txt	4,236
artifacts/VAPTORMSF/msf_137_74_187_101.txt	4,401

Artifact Path	Size (bytes)
artifacts/VAPTORMSF/msf_137_74_187_102.txt	4,566
artifacts/VAPTORMSF/msf_137_74_187_103.txt	4,346
artifacts/VAPTORMSF/msf_137_74_187_104.txt	4,841
artifacts/VAPTORMSF/msf_178_79_134_182.txt	1,534
artifacts/VAPTORMSF/msf_31_3_96_40.txt	124,460
artifacts/VAPTORMSF/msf_44_228_249_3.txt	3,112
artifacts/VAPTORMSF/msf_44_238_29_244.txt	3,151
artifacts/VAPTORMSF/msf_81_169_145_156.txt	6,636
artifacts/metasploit_auth/auth_10_0_0_132.rc	324
artifacts/metasploit_auth/msf_auth_10_0_0_132.txt	2,191
artifacts/metasploit_auth/userpass_trimmed.userpass.txt	7,068
artifacts/mitm/VAPTORARP20260311172652.log	15,683,109
artifacts/mitm/VAPTORARP20260311172717.log	377
artifacts/mitm/VAPTORCAP20260311172716_00001_20260311172717.pcapng	299,886,164

Artifact Path	Size (bytes)
artifacts/mitm/VAPTORPCAP20260311172716.log	21,515
artifacts/mitm/pcap_summary.json	653
artifacts/mitm/recon_observations.json	12,659
artifacts/msf_auth.json	4,330
artifacts/msf_verification.json	9,529
artifacts/VAPTORDISCOVERY.txt	410
artifacts/phases_summary.json	1,868
artifacts/sast/.gitleaks.toml	541
artifacts/sast/bandit_results.json	407
artifacts/sast/bearer_results.json	86,421
artifacts/sast/gitleaks_results.json	3
artifacts/sast/sast_summary.json	779
artifacts/scan_events.jsonl	1,668
artifacts/scanner_execution.json	3,028

Artifact Path	Size (bytes)
artifacts/scanner_validation.json	903
artifacts/scanner_validation_penetration_test.json	541
artifacts/scanner_validation_vulnerability_assessment.json	564
artifacts/sqlmap_http___www.itsecgames.com/www.itsecgames.com/log	0
artifacts/sqlmap_http___www.itsecgames.com/www.itsecgames.com/session.sqlite	8,192
artifacts/sqlmap_http___www.itsecgames.com/www.itsecgames.com/target.txt	246
artifacts/sqlmap_https___owasp-juice.shop/owasp-juice.shop/log	0
artifacts/sqlmap_https___owasp-juice.shop/owasp-juice.shop/session.sqlite	8,192
artifacts/sqlmap_https___owasp-juice.shop/owasp-juice.shop/target.txt	243
artifacts/sqlmap_https___pentest-ground.com/pentest-ground.com/log	0
artifacts/sqlmap_https___pentest-ground.com/pentest-ground.com/session.sqlite	8,192
artifacts/sqlmap_https___pentest-ground.com/pentest-ground.com/target.txt	249
artifacts/sqlmap_https___www.hackthissite.org/www.hackthissite.org/log	0
artifacts/sqlmap_https___www.hackthissite.org/www.hackthissite.org/session.sqlite	8,192

Artifact Path	Size (bytes)
artifacts/sqlmap_https___www.hackthissite.org/www.hackthissite.org/target.txt	255
artifacts/sqlmap_results.json	403
artifacts/vaptorgpt.json	43,140
artifacts/waf_vhost.json	944
artifacts/web_recon.json	14,670
artifacts/web_target_gating.json	1,196
artifacts/websites.json	9,198
artifacts/zap_http_www.itsecgames.com.json	19,952
artifacts/zap_https_owasp-juice.shop.json	35,824
artifacts/zap_https_pentest-ground.com.json	413,783
artifacts/zap_results.json	149,946
audit/audit_analysis.json	126,818
audit/include_in_report.flag	8